TECFEST 2026

WEEKLY PRACTICE

Homework 02

Eksplorasi Kategori CTF



Ni Made Suindri Karaskanaka

260530911006

Daftar Isi

Daftar Isi 2
Reverse Engineering 3
1 Reverse 1 – My First Crackme 3
2 Reverse 2 - Babyrev 10
Web Exploitation 14
1. Web 1 – Old Session 14
2. Web 2 – Crack The Gate 1 21
Daftar Pustaka 27

Reverse Engineering

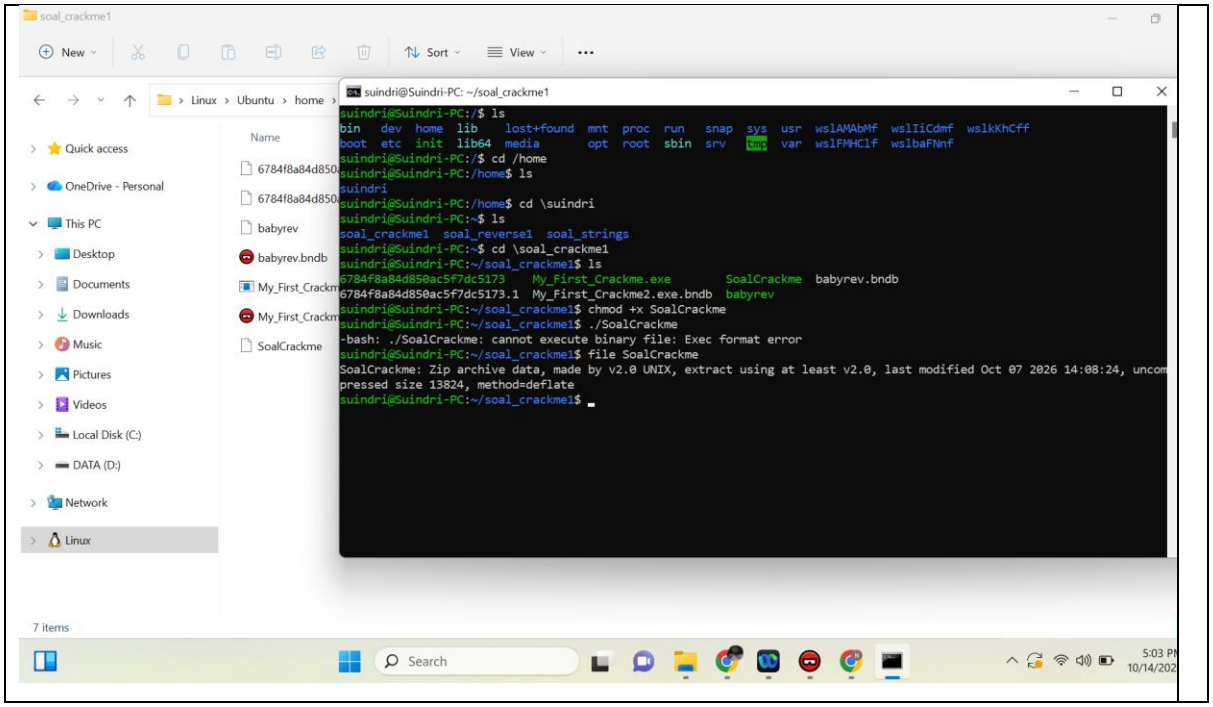
Reverse Engineering adalah salah satu cabang dari *cyber security* yang bertujuan untuk membongkar atau menganalisis suatu sistem, perangkat lunak, atau aplikasi untuk memahami cara kerja bagian-bagain di dalamnya. Dalam konteks *Capture The Flag* (CTF), terdapat berbagai platform latihan yang populer seperti CylabAcademy dan Crames.one. CylabAcademi menyediakan pembelajaran dan latihan-latihan seperti tantangan CTF. Sedangkan Crackmes.one adalah situs komunitas dimana para pengembang dan peminat keamanan *cyber* dapat mengunggah ataupun memecahkan berbagai tantangan (crackmes) dengan tingkat kesulitan berbeda untuk menemukan *flag* rahasianya di dalamnya.

Kala itu, saya belajar reverse bersama kakak-kakak TI yang baik hati membagikan ilmu kepada adik-adik tingkatnya. Karena masalah pada server CylabAcademy di Hari Kamis, 8 Oktober 2026, Kak Sanca mengarahkann menggunakan Crackmes.ones, dan memberikan saya kemudahan untuk mengerjakan 2 soal reverse dan 2 soal lainnya. Untuk soal Berikut *Write Up* yang saya buat.

1 Reverse 1 – My First Crackme

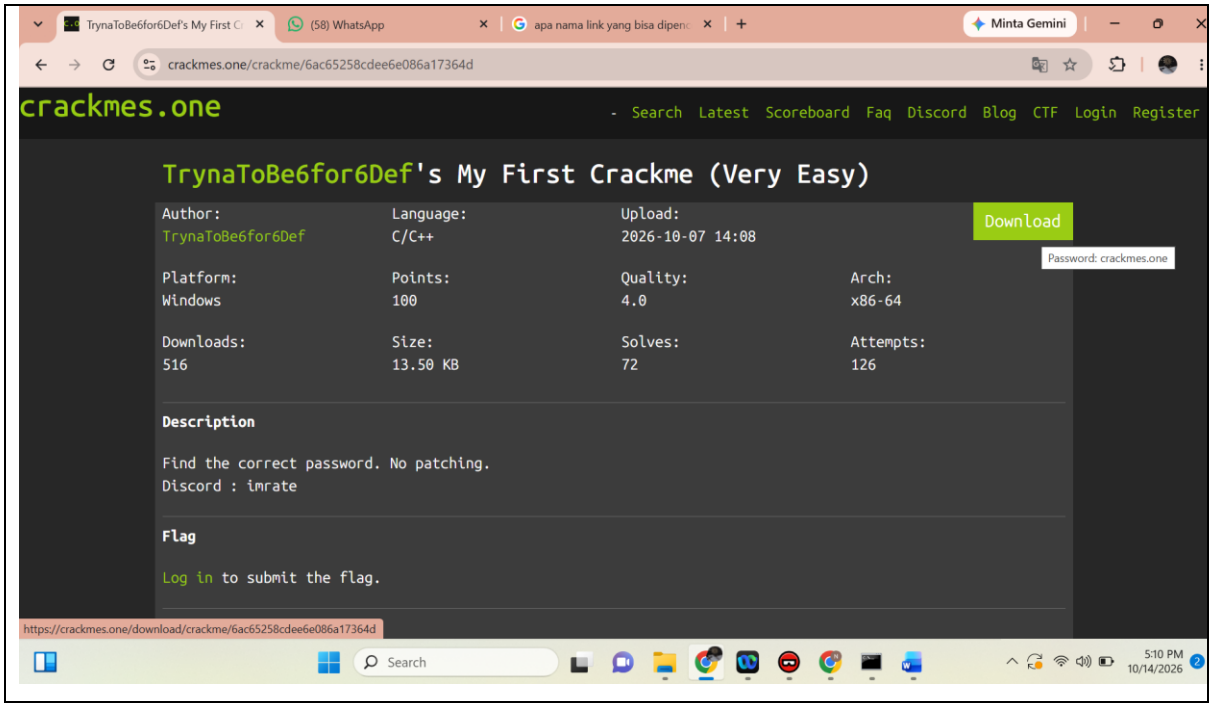
Link soal : https://crackmes.one/crackme/6ac65258cdee6e086a17364d

Pertama, buka command promt, masuk ke wsl, lalu buat directory baru supaya rapi (tips dari Kak Sanca). Untuk membuat directory baru, saya menggunakan perintah `mkdir <NamaDirectory>`. Supaya keren, download lewat wsl. Caranya? Masuk ke dalam halaman website, lalu salin link download dan download lewat wsl dengan perintah `wget <urlFile>`.



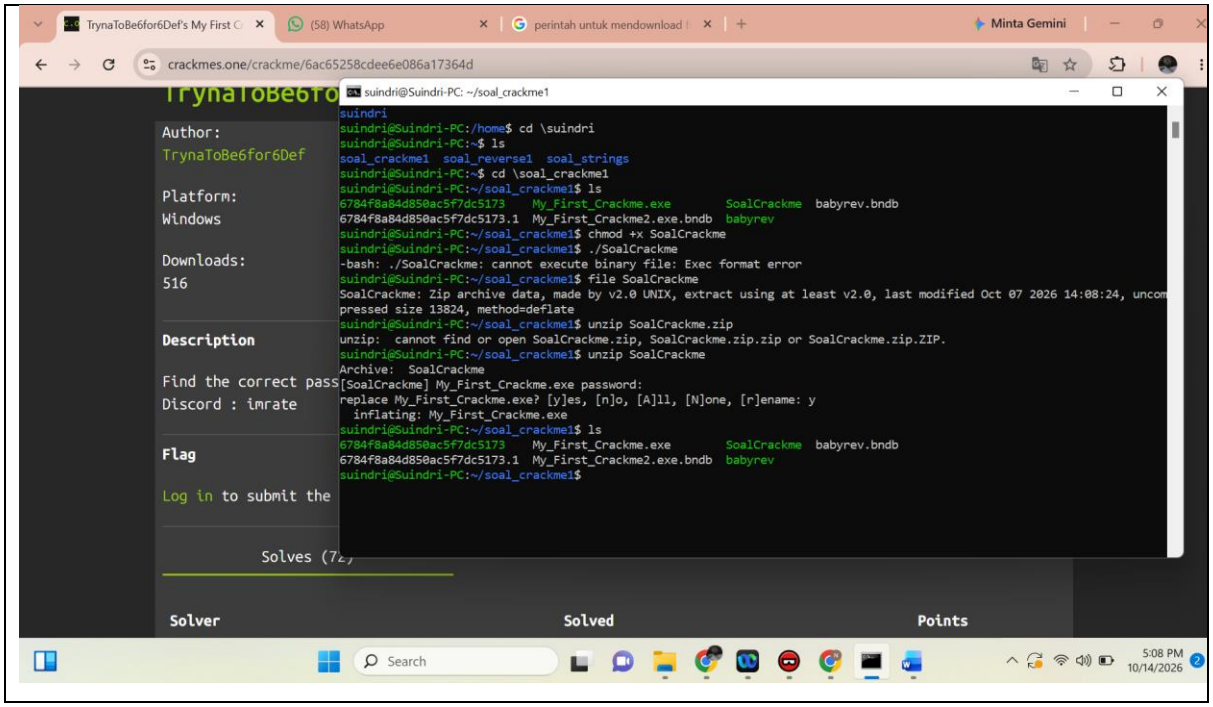
Gambar 1.1 wsl mencari lokasi file

Oke, sebenarnya saya sudah menyelesaikannya, dan sekarang akan menjelaskan kembali langkah-langkahnya. Karena sudah ada, saya masuk saja ke tempat penyimpanannya dengan perintah `cd <NamaDirectory>`. Karena file yang diunduh berupa `zip`, maka perlu di `unzip` dengan perintah `unzip <NamaFile.zip>`. Tapi, dimiinta *password*-nya. Jadi, harus kembali ke halaman cracmes.one nya.



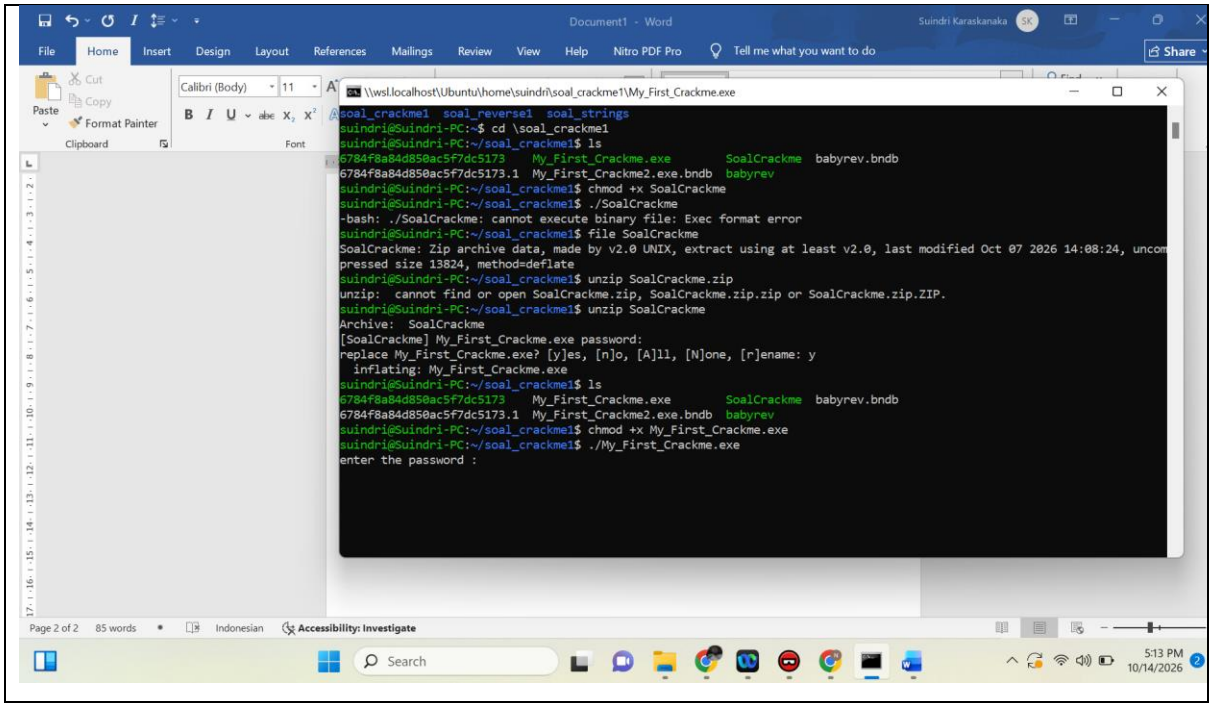
Gambar 1.2 mencari password untuk di unzip

Cukup letakkan kursor di atas button “Donwload” berwarna hijau tersebut. Passwordnya akan muncul setelah kursor diletakkan diatas button tersebut setelah beberapa detik.



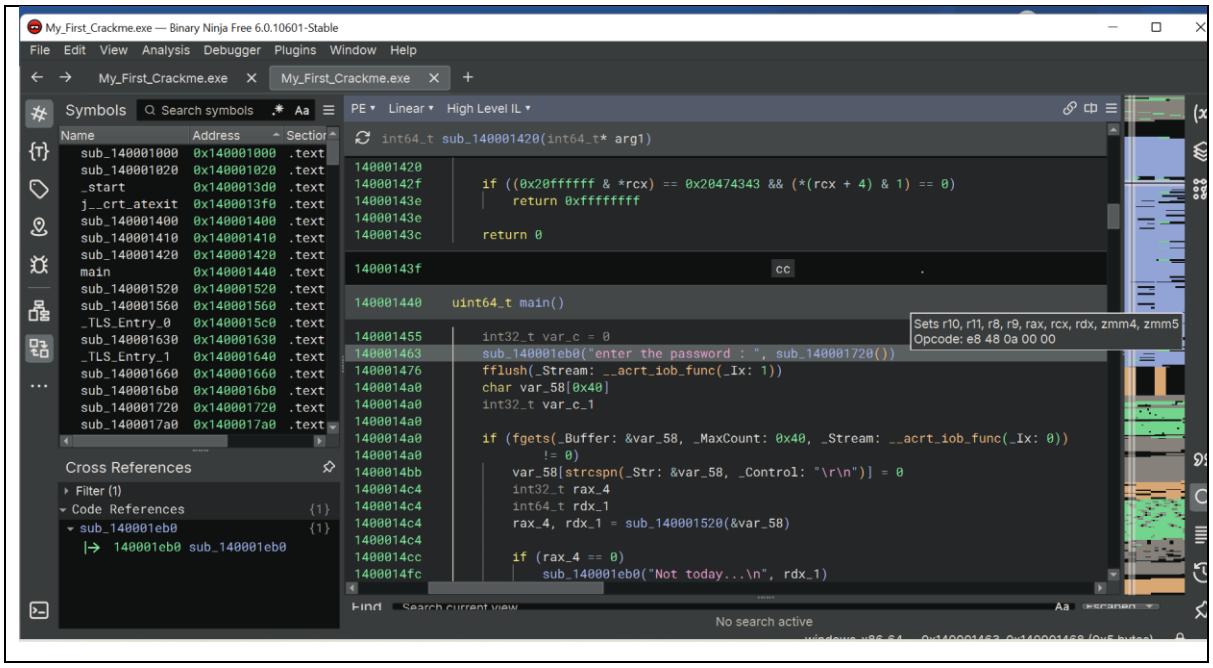
Gambar 1.3 setelah unzip

Sekarang saya punya 2 file crackme (karena sudah pernah melalui step ini tapi lupa *screenshoot*). Oke, lanjut saja. Gunakan perintah `chmod +x <NamaFile>` dan `./<NamaFile>` untuk mengeksekusi file



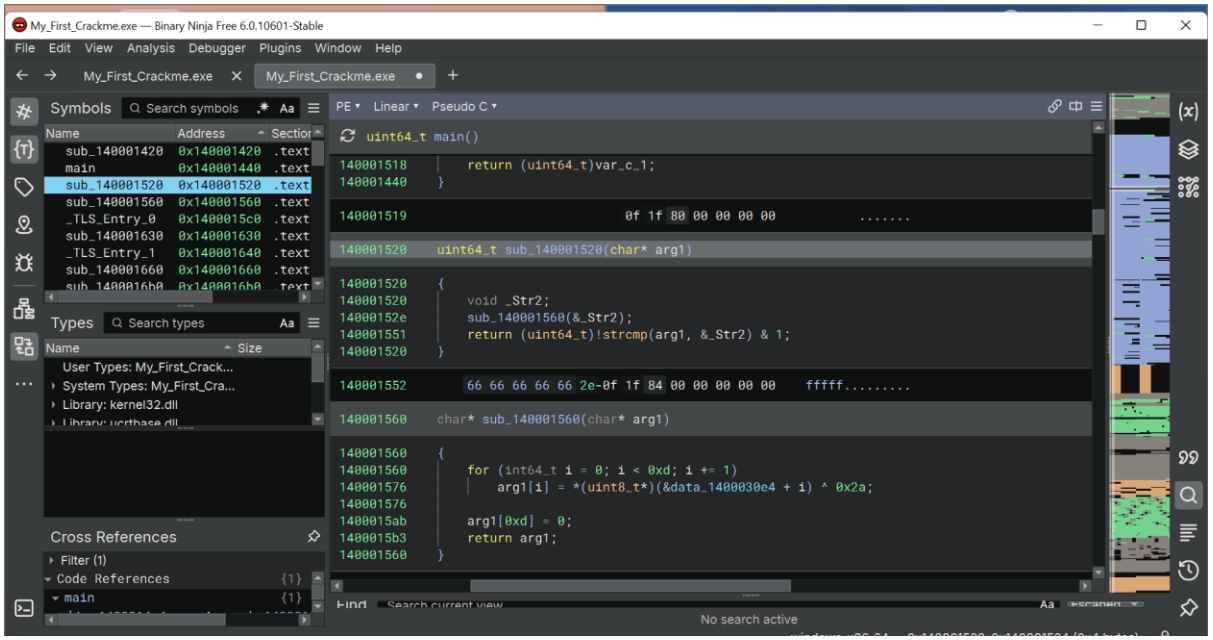
Gambar 1.4 setelah unzip

Nah, ini diminta *password* lagi. Kalo kata saya, inilah waktunya menggunakan alat atau *tools* yang telah dirancang sedemikian rupa untuk membantu kita menemukan *password*-nya. Kalo kata Kak Sanca, “pake Binary Ninja.”



Gambar 1.5 di dalam Binary Ninja

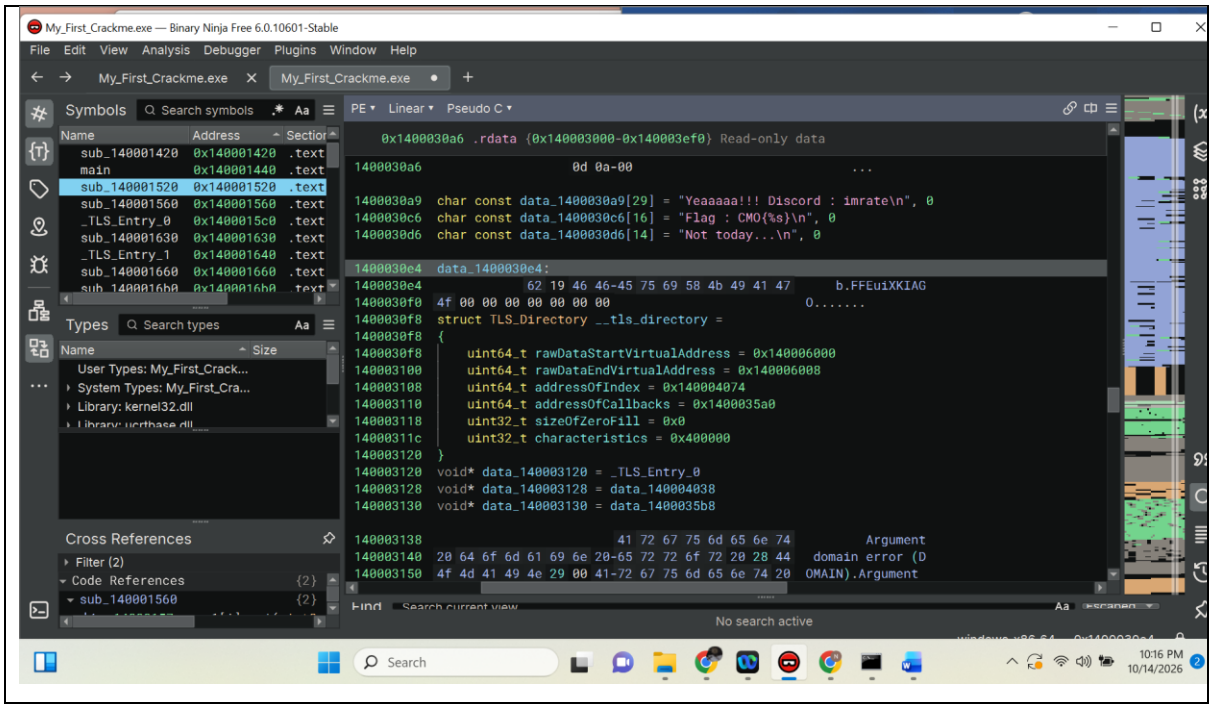
Di Binary Ninja, cari fungsi `main()` nya. Lihatlah, ada *password* dalam bahasa lain (bukan bahasa manusia). Jika dilihat alur programnya, jika `rax_4` bernilai 0 atau salah, program akan mencetak `"Not today...\n"`. Jika bernilai bukan 0, maka program akan memanggil fungsi `sub_140001520(var_66)`. Lalu, klik dua kali `sub_140001520()` untuk mengecek isinya.



Gambar 1.6 isi

Disini, bisa dilihat cara program menghasilkan dan memeriksa *password* tersebut. Pada pengecekan password, Fungsi mendeklarasikan variabel `_Str2`.Memanggil fungsi `sub_140001560(&_Str2)` untuk mengisi `string _Str2`. Membandingkan input pengguna (`arg1`) dengan `_Str2` menggunakan `strcmp(arg1, &_Str2)`.

Program akan melakukan looping sebanyak 0*d, yaitu 13 karakter dari i sama dengan 0, sampai i lebih kecil dari 13. Setiap karakter diambil dari alamat `data_1400030e4 + 1`, kemudian di `XOR` dengan nilai `0x2a` (42). Jadi, kita cek dulu isi `data_1400030e4`.



Gambar 1.7 isi data_400030e4

Byte *hexadecimal* dari alamat data tersebut adalah :

0x62, 0x19, 0x46, 0x46, 0x45, 0x75, 0x69, 0x58, 0x4b, 0x49, 0x41, 0x47

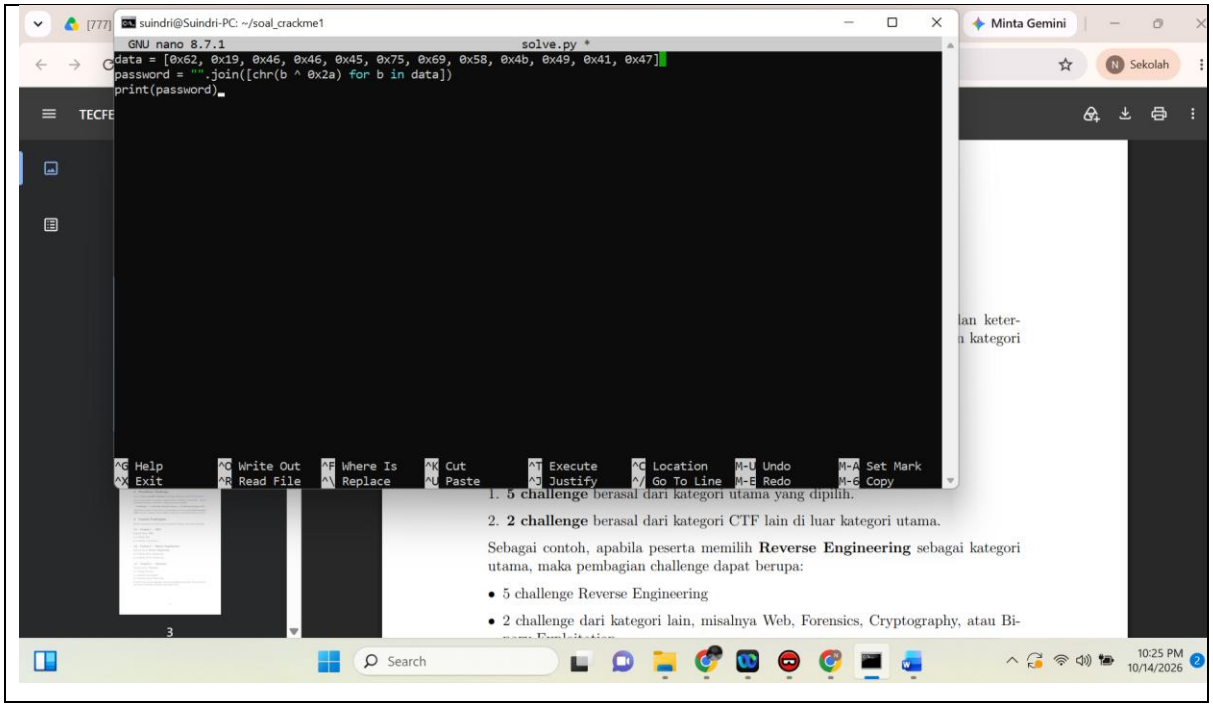
Kemarin, saya dan Kak Sanca menggunakan banuan kecerdasan buatan untuk mentranslasikan kodenya. Namun, saat menulis Write up ini saya menemukan sebuah script kecil dengan phyton untuk menjalankan perhitungan `xor` di dalam command promt wsl.

```
nano solve.py //membuat file phyton baru

//untuk mengubahnya
data = [0x62, 0x19, 0x46, 0x46, 0x45, 0x75, 0x69, 0x58, 0x4b, 0x49, 0x41,
0x47, 0x4f]
password = "".join([chr(b ^ 0x2a) for b in data])
print(password)
```

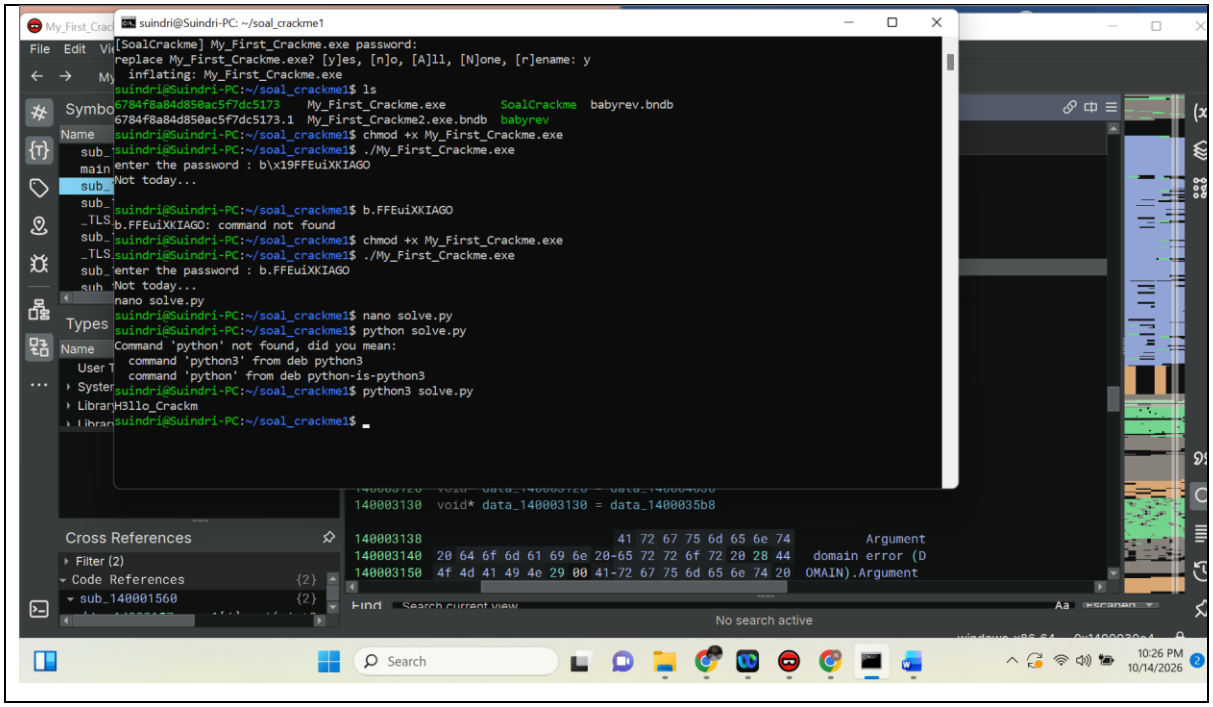
```
python3 solve.py //mengeksekusi
```

Kode Program 1.1 Python



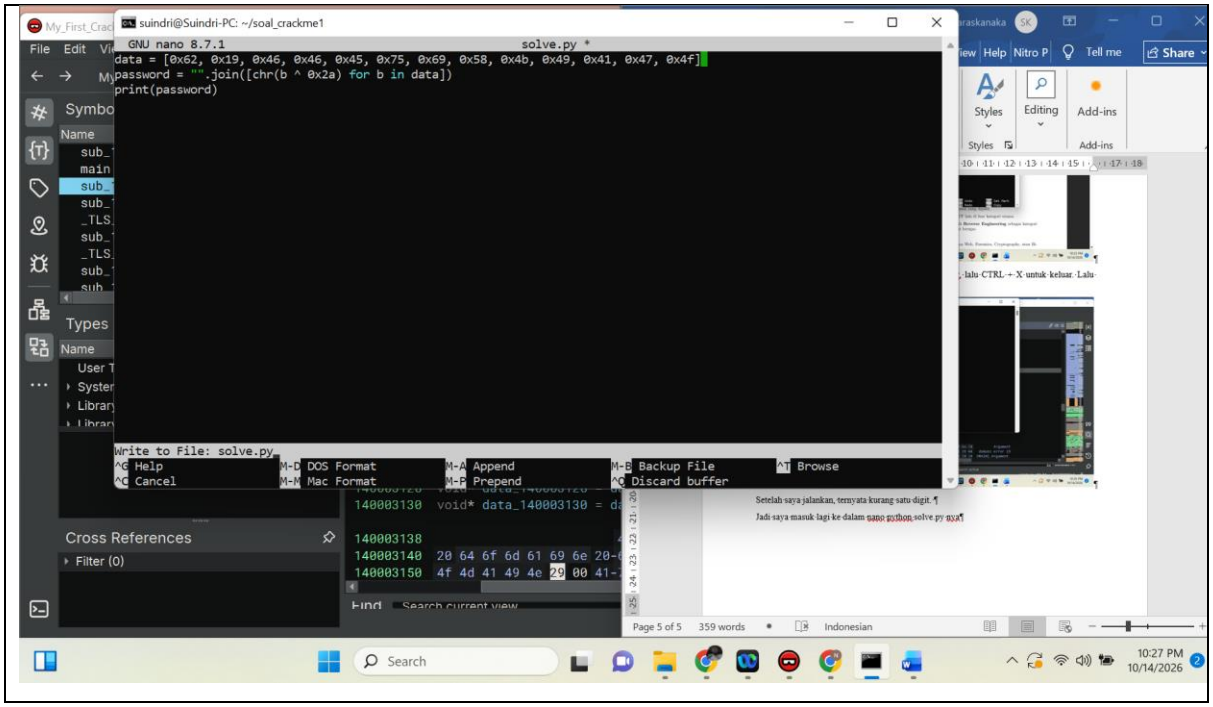
Gambar 1.8 di dalamfile phyton

Masukkan operasi `xor`, `CTRL + O` untuk simpan, enter, lalu `CTRL + X` untuk keluar. Lalu jalankan script.



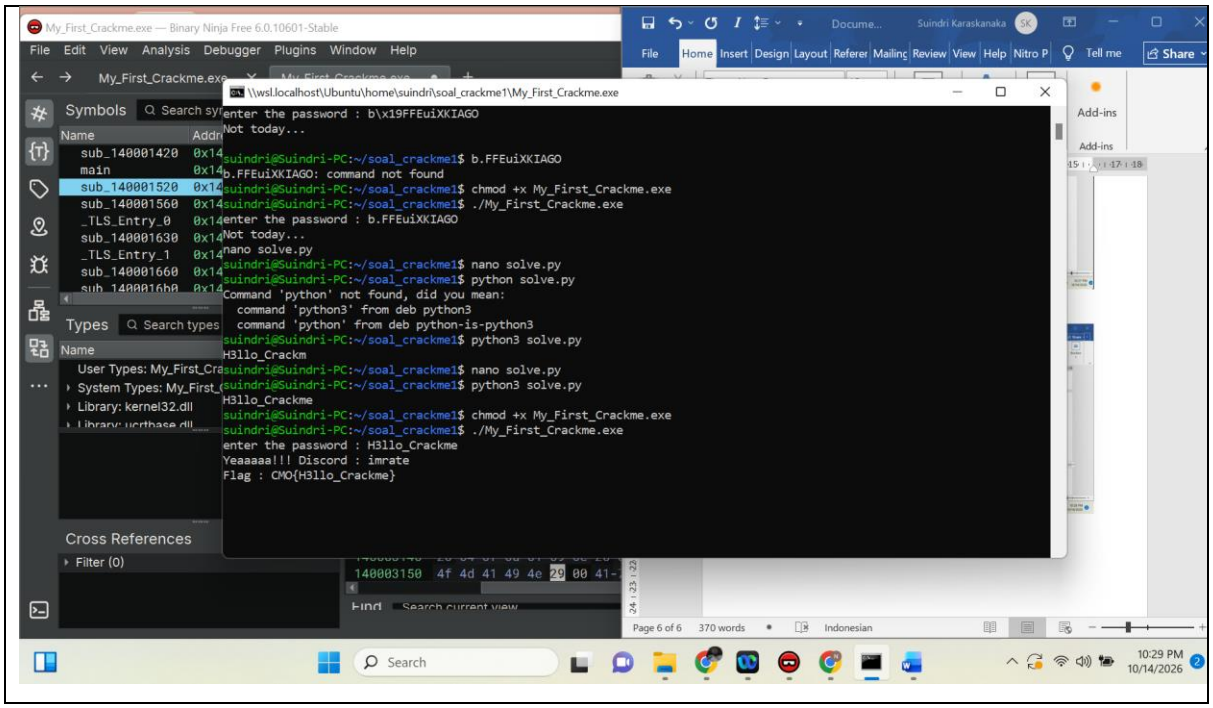
Gambar 1.9 hasil eksekusi dengan phyton

Setelah saya jalankan, ternyata kurang satu digit.



Gambar 1.10 di dalam python lagi

Jadi saya masuk lagi ke dalam nano python solve.py nya



Gambar 1.11 eksekusi pyhton ke-2

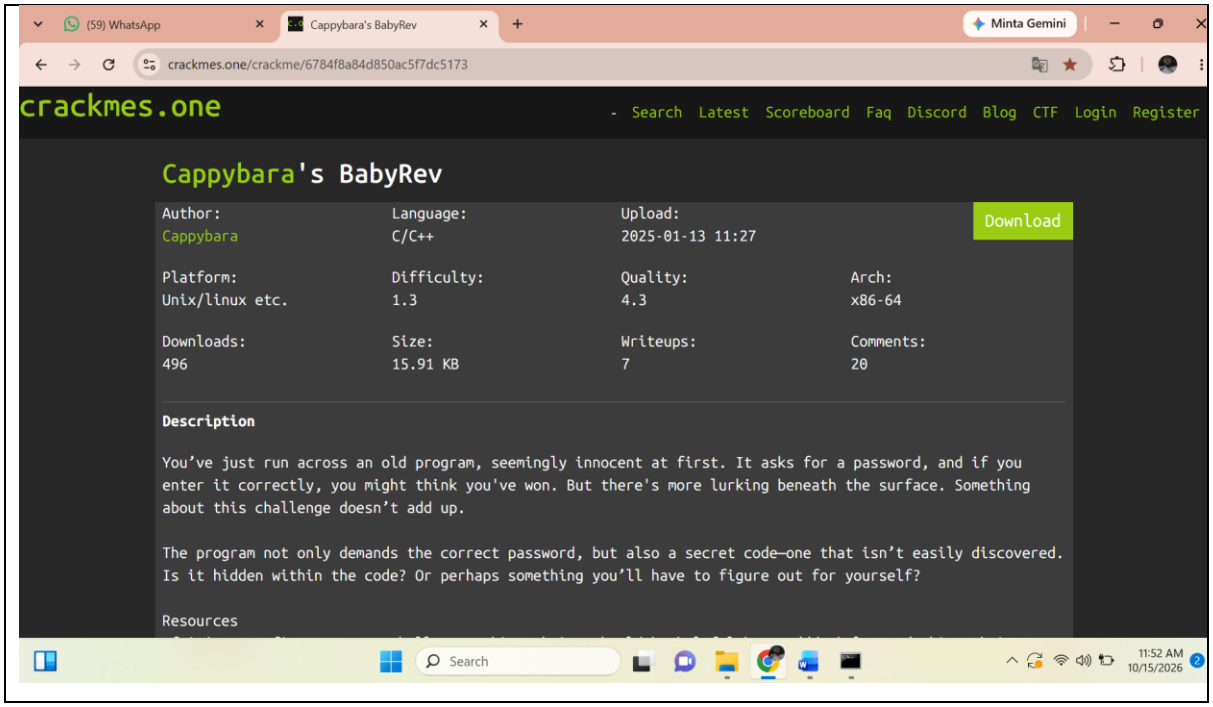
Inilah dia pw nya. Saya masukkan, lalu saya mendapatkan flagnya.

```
CMO{H3llo_Crackme}
```

2 Reverse 2 - Babyrev

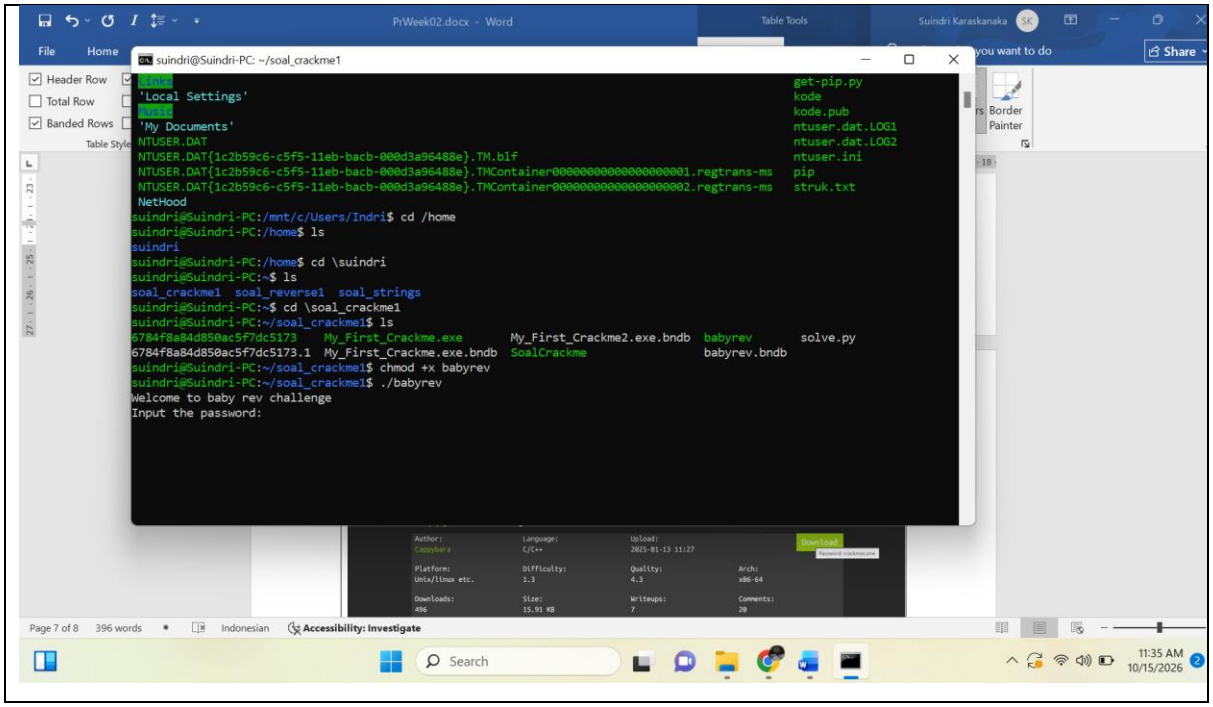
Untuk soal ke dua, Kak Sanca menugaskan untuk mencari **babyrev** di *web browser*. Lalu masuklah kita ke dalam tampilan website seperti ini.

Link soal : *https://crackmes.one/crackme/6784f8a84d850ac5f7dc5173*



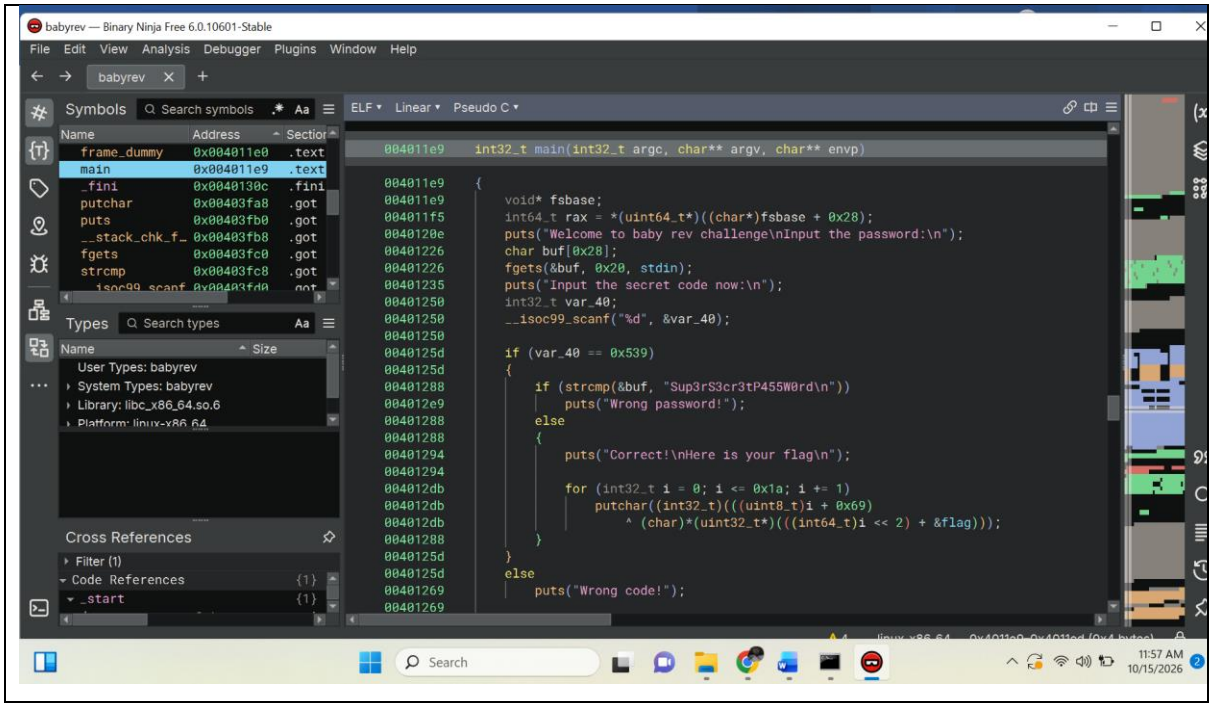
Gambar 2.1 soal Crackme ke-2

Setelah itu, buka command prompt dan masuk mode wsl (membuka linux). Salin *url* dan *password*-nya. Kemudian, download dengan perintah `wget <url>`. Di sini, juga perlu `unzip` dan masukkan *password.*



Gambar 2.2 unzip

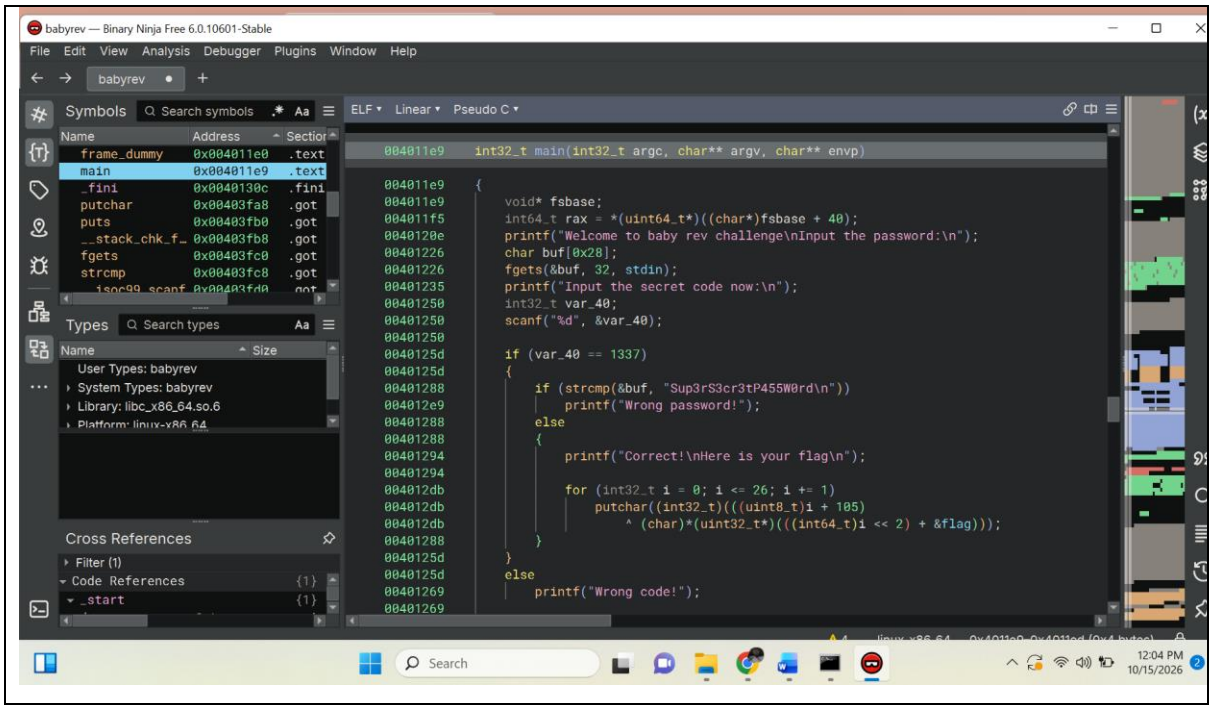
Masuk ke dalam lokasi file yang telah di `unzip`, lalu eksekusi file dengan perintah `chmod +x <NamaFile>`, `./<NamaFile>`. Di soal ini, diminta juga *password* untuk masuk ke dalam. Jadi, perlu menggunakna binary ninja lagi.



Gambar 2.3 Binary Ninja Babyrev

Di Binary Ninja, masuk ke dalam fungsi `main()`. Lalu, kita telaah perlahan kodenya. Ubah menjadi bahasa *high level* supaya lebih mudah dimengerti, ubah angka *hex* menjadi *decimal*,

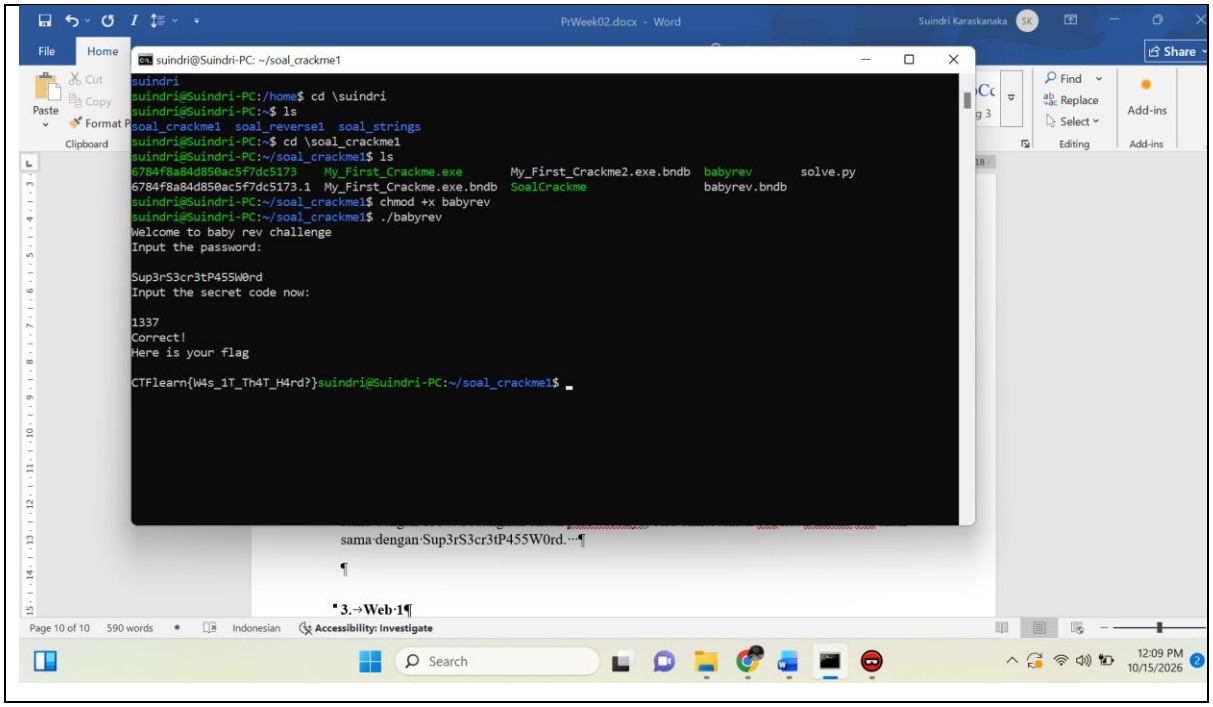
dan *rename* beberapa hal di binary ninja untuk mempermudah proses mencari flagnya. Lalu menjadi seperti berikut.



Gambar 2.4 Binary Ninja Babyre setelah di rename beberapa

Nah, disini bisa kita lihat ada ...`input the password : char buf[0x28}...` dan *nested if*. Jika `var_40` sama dengan `1337`, jalankan kode berikutnya. Jika `&buf` dan `Sup3rS3cr3tP455W0rd` sama, maka cetak "`wrong password`". Jika selain semua itu,, "`wrong code`".

Berarti ada 2 hal yang diminta, *password* dan *code*. Berarti untuk kodenya adalah nilai yang sama dengan `1337`. Sedangkan untuk *password*-nya, bisa dimasukkan `&buf` itu. Dimana `&buf` akan sama dengan `Sup3rS3cr3tP455W0rd`.



Gambar 2.5 memasukkan password dan code yang diminta

Maka, flagnya adalah

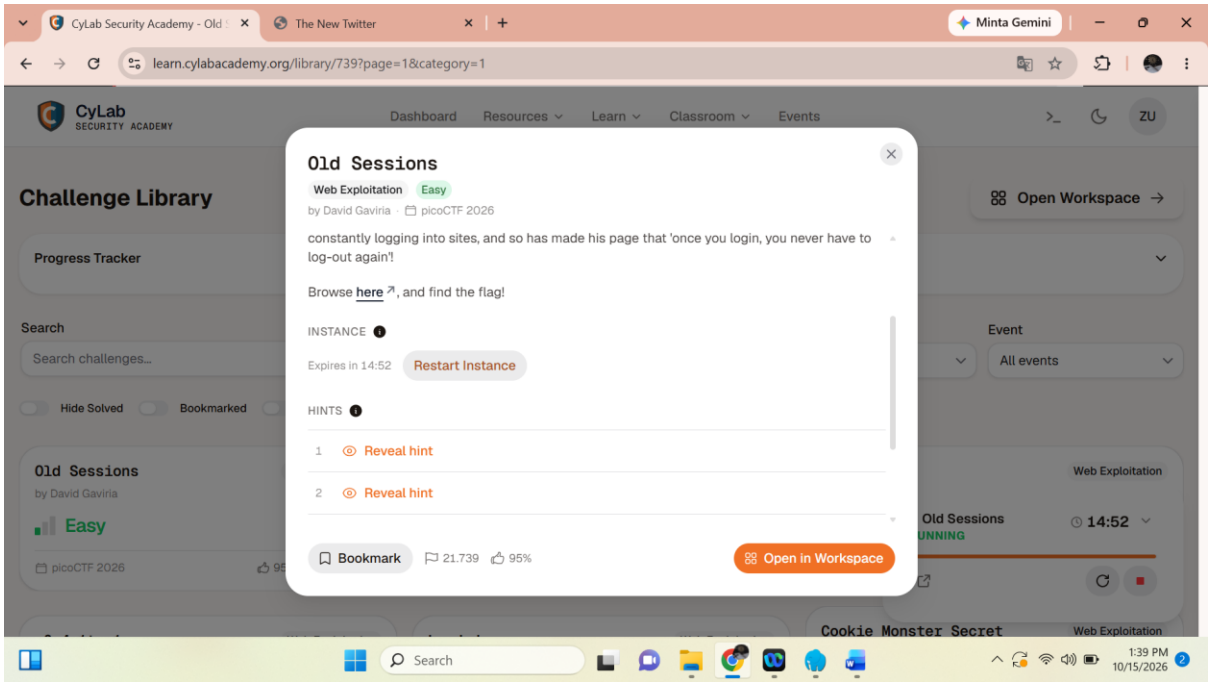
```
CTFlearn{W4s_1T_Th4T_H4rd?}
```

Web Exploitation

Secara umum, *web exploitation* adalah cara untuk mencari dan memanfaatkan celah keamanan di suatu situs web agar kita bisa masuk atau mengambil data tanpa izin. Dalam dunia *Capture The Flag* (CTF), *web exploitation* menjadi salah satu kategori tantangan dengan meretas aplikasi web yang sengaja dibuat "bocor" demi menemukan kunci rahasia berupa *flag*. Platform seperti CyLab Security Academy merupakan tempat latihan interaktif yang pas untuk mempelajari bagaimana server bisa terkecoh oleh *input* pengguna sekaligus paham cara memperbaikinya.

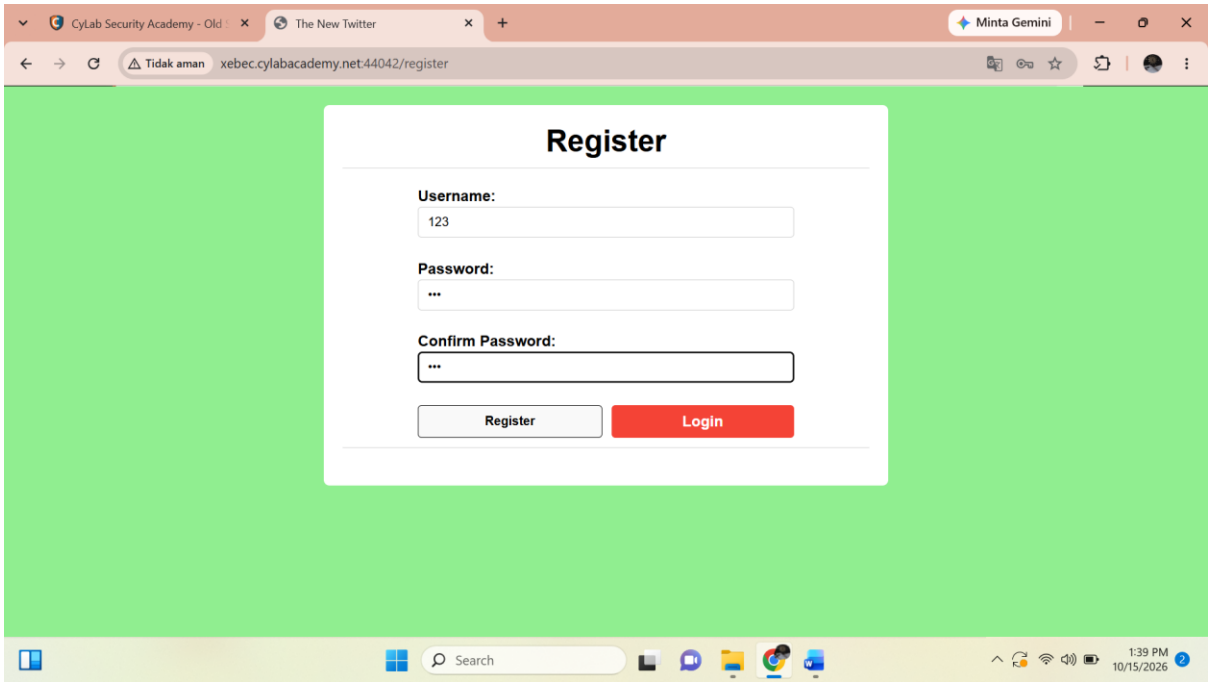
1. Web 1 – Old Session

Link soal : *https://learn.cylabacademy.org/library?page=1&category=1*



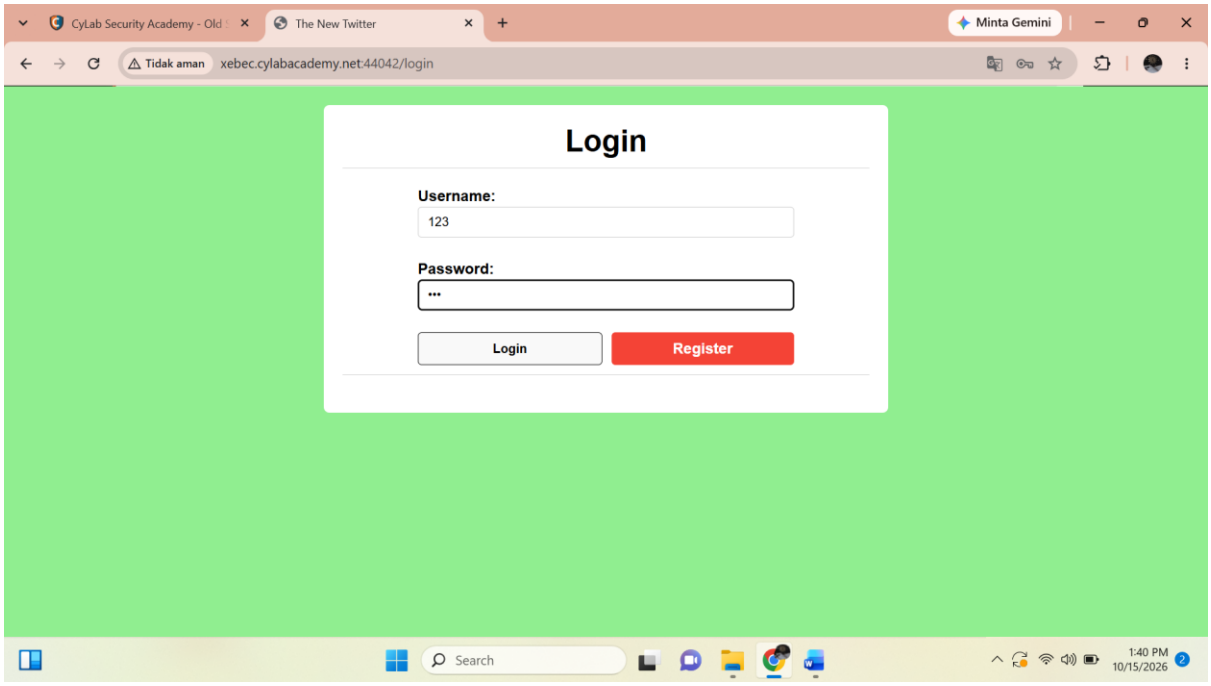
Gambar 1.1 soal Old Session

Pertama, buka salah satu soal *web exploitation* yang tersedia di CylabAcademy, lalu *start instance*. Setelah itu, baca hint dan klik browse “here”.



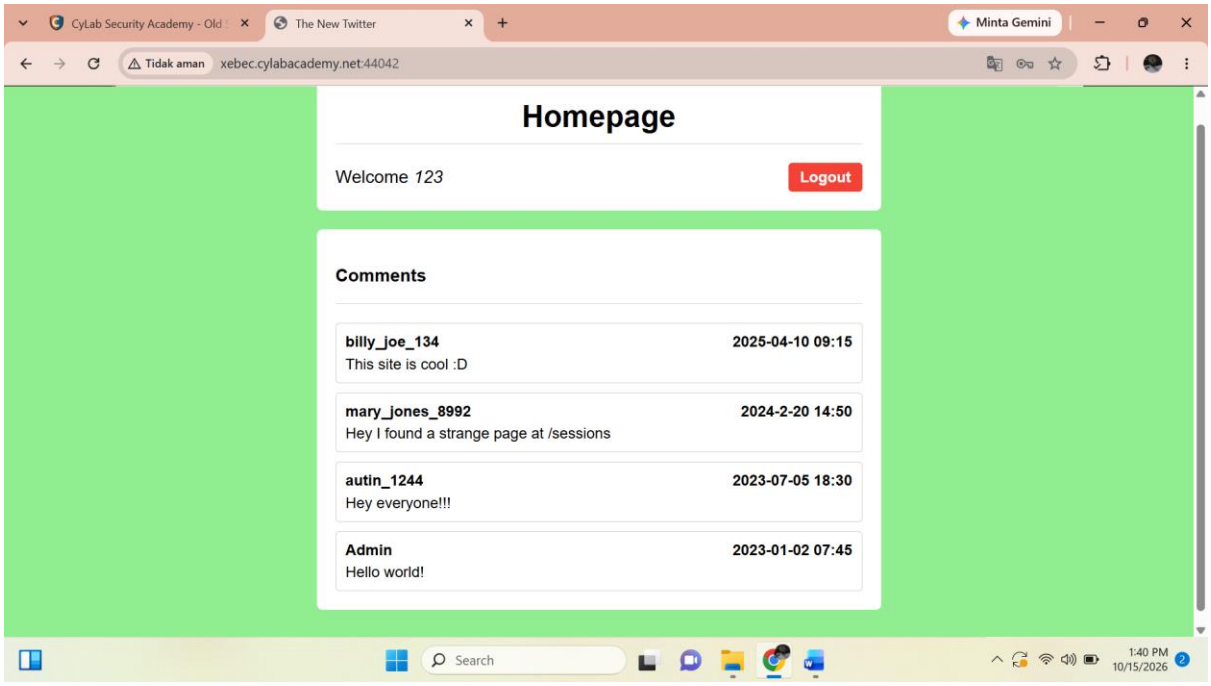
Gambar 1.2 Halaman Register

Daftar saja sebagai *random*, tapi ingat nama pengguna dan kata sandi yang digunakan. Disini, saya menggunakan 123 untuk kata sandi dan nama penggunanya.



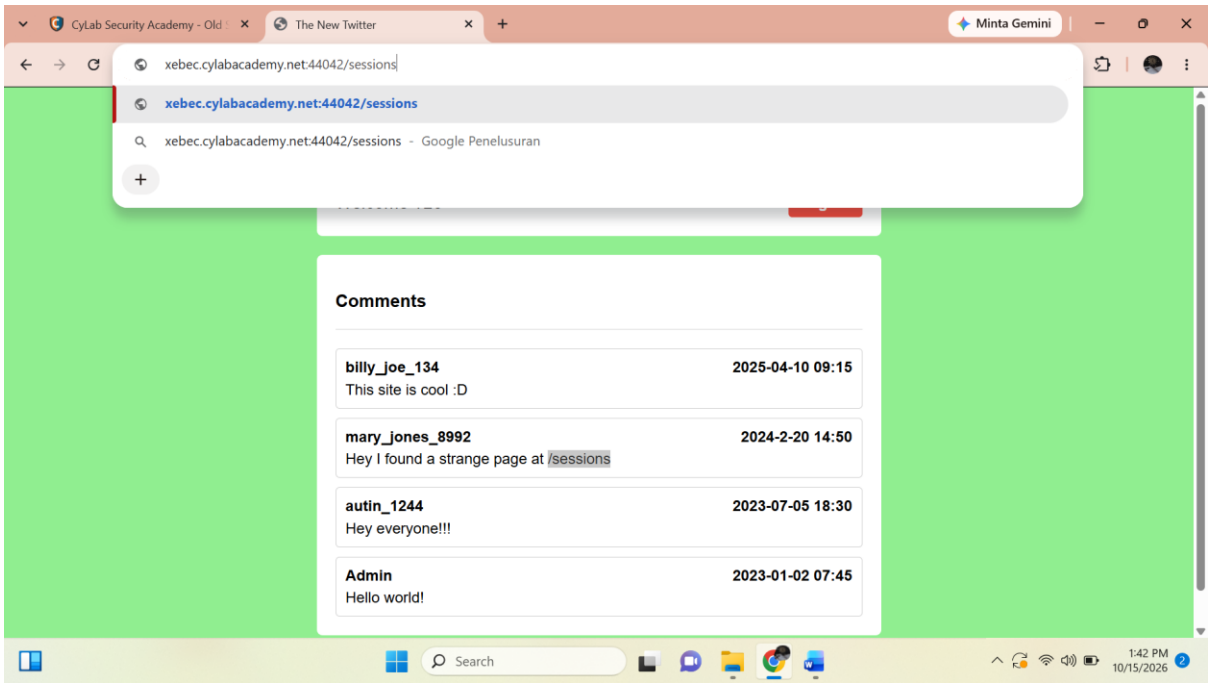
Gambar 1.3 Login

Setelah itu, masukkan kembali nama pengguna dan kata sandi tadi, lalu klik Login. Halaman website akan mengarahkan kita ke homepage. Disinilah analisis dimulai.



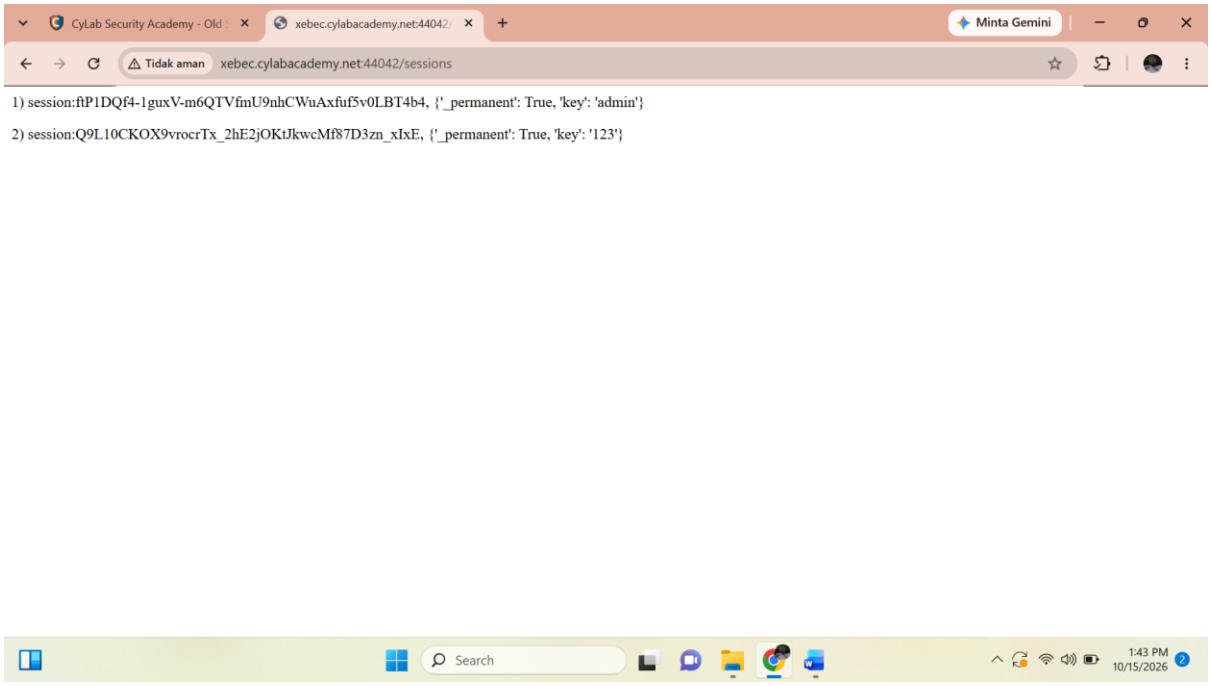
Gambar 1.4 Home Page Old Session

Disini, ada user mary_jones_8992 yang menulis komentar “Hey I found a strange page at /session”. Ini merupakan petunjuk penting.



Gambar 1.5 /session

Tambahkan `/session` pada url. Lalu analisis kembali.



Gambar 1.6 *Web Page* setelah ditambahkan

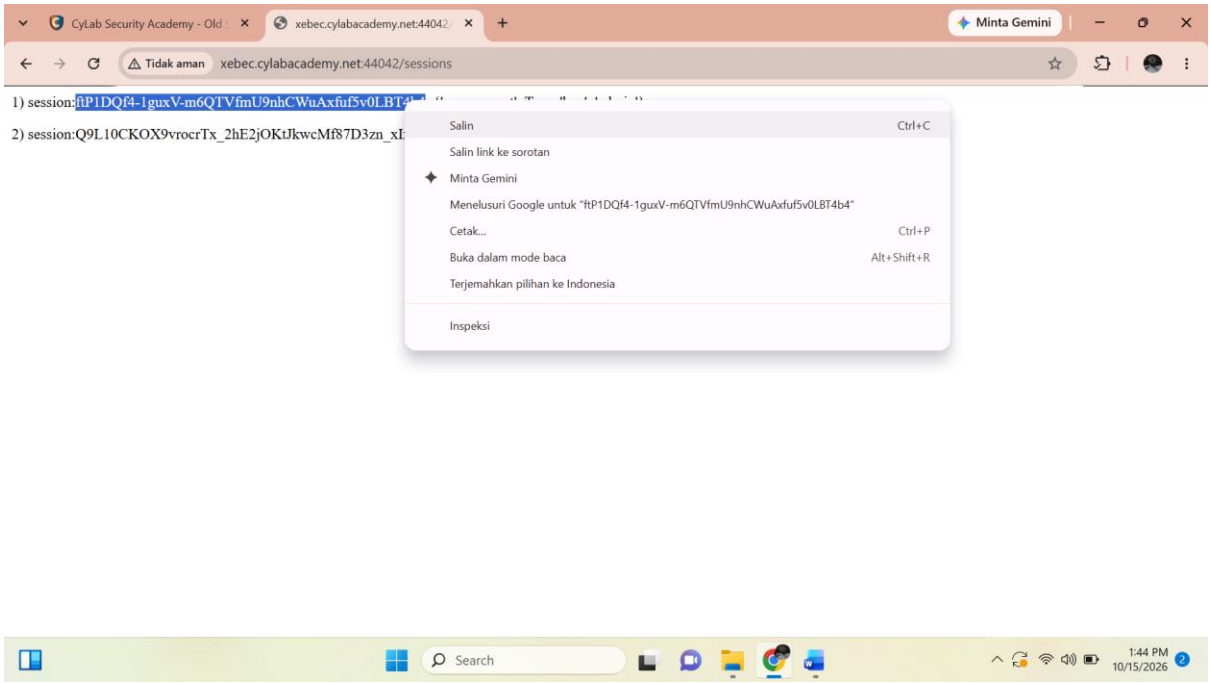
Disini, ada beberapa kerentanan yang bisa dilihat :

a. **Penyimpanan Sesi yang Terbuka untuk Publik:** Endpoint URL /sessions menampilkan daftar seluruh ID sesi aktif beserta informasi objek pengguna (seperti kunci 'key': 'admin' dan 'key': '123') secara transparan kepada siapa saja yang mengakses halaman tersebut

b. **Kurangnya Kontrol Akses (*Access Control*):** Halaman aplikasi seharusnya menyembunyikan atau melindungi data sensitif seperti token sesi (*session token*) agar tidak bisa dibaca oleh pengguna biasa atau pihak luar.

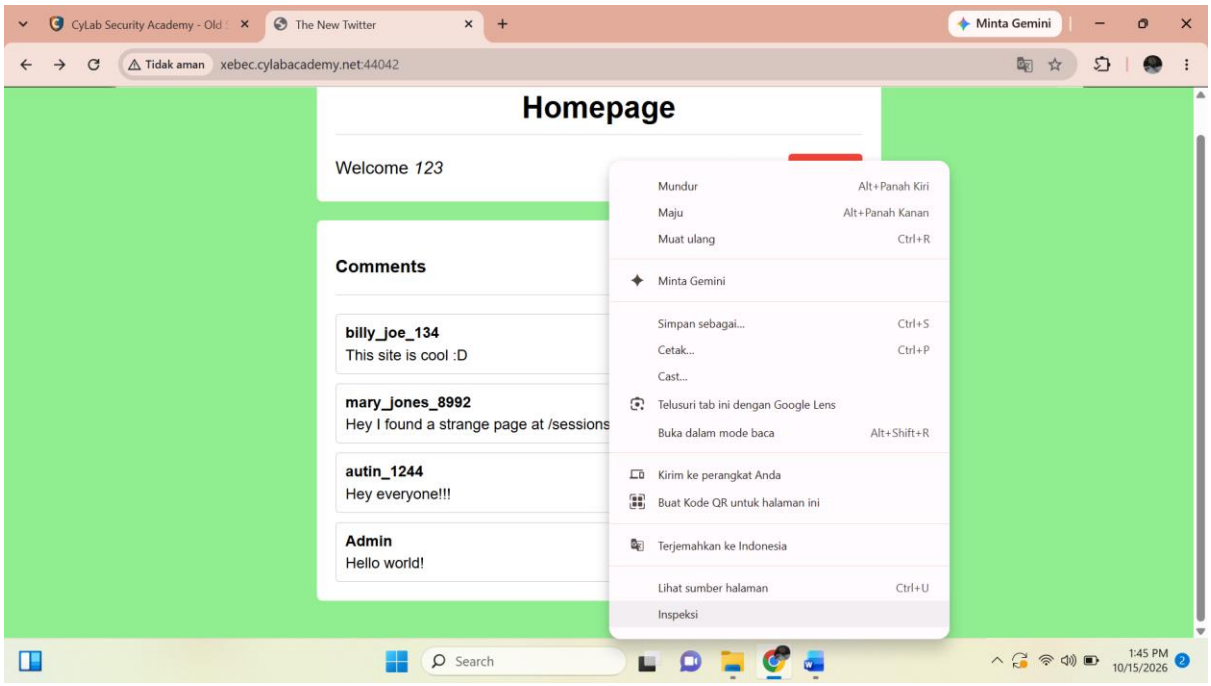
c. **Celah Pembajakan Sesi (*Session Hijacking*):** Karena token sesi milik akun administrator (admin) terpampang secara langsung, siapa pun dapat menyalin nilai token tersebut ke dalam kuki (*cookie*) browser mereka untuk mengambil alih akun admin tanpa perlu mengetahui kata sandinya.

Next, time to exploitation! Mwehehe:v



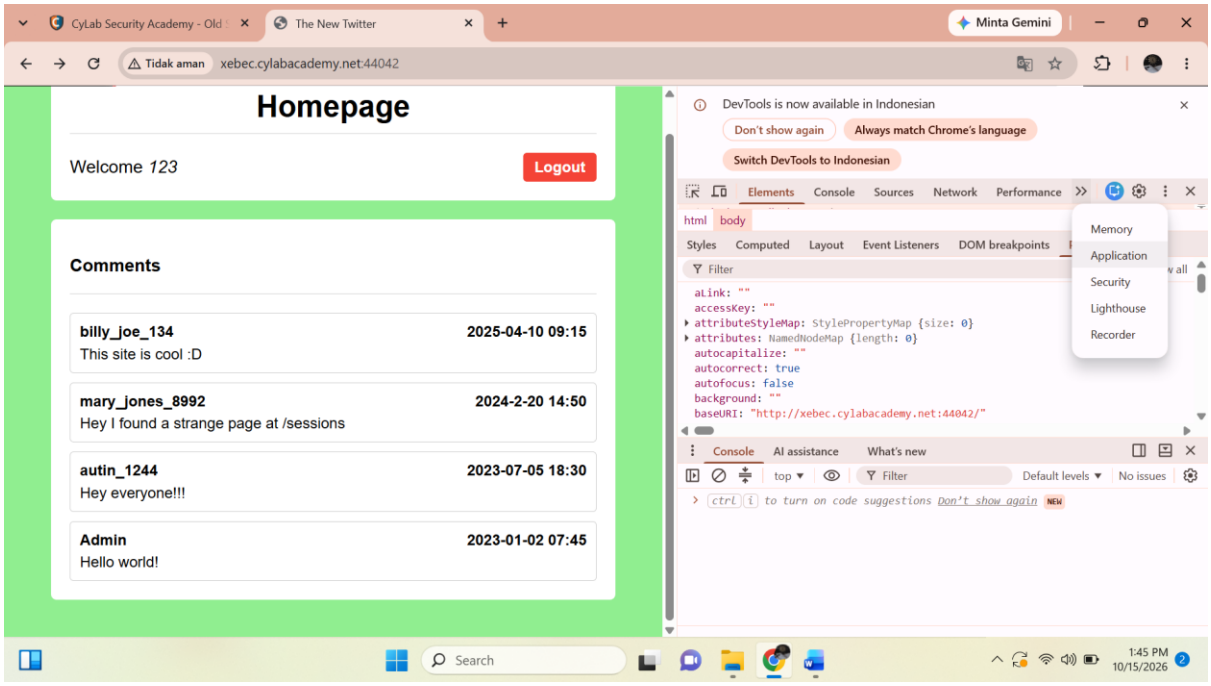
Gambar 1.7 Meng-*copy* string di Sesi Admin

Salin string yang ada di sesi admin (mau masuk sebagai admin) "ftP1DQf4-1guxV-m6QTVfmU9nhCWuAxfuf5v0LBT4b4". Lalu kembali ke halaman utama web nya. Kita akan melakukan injeksi ke dalam *cookie*-nya.



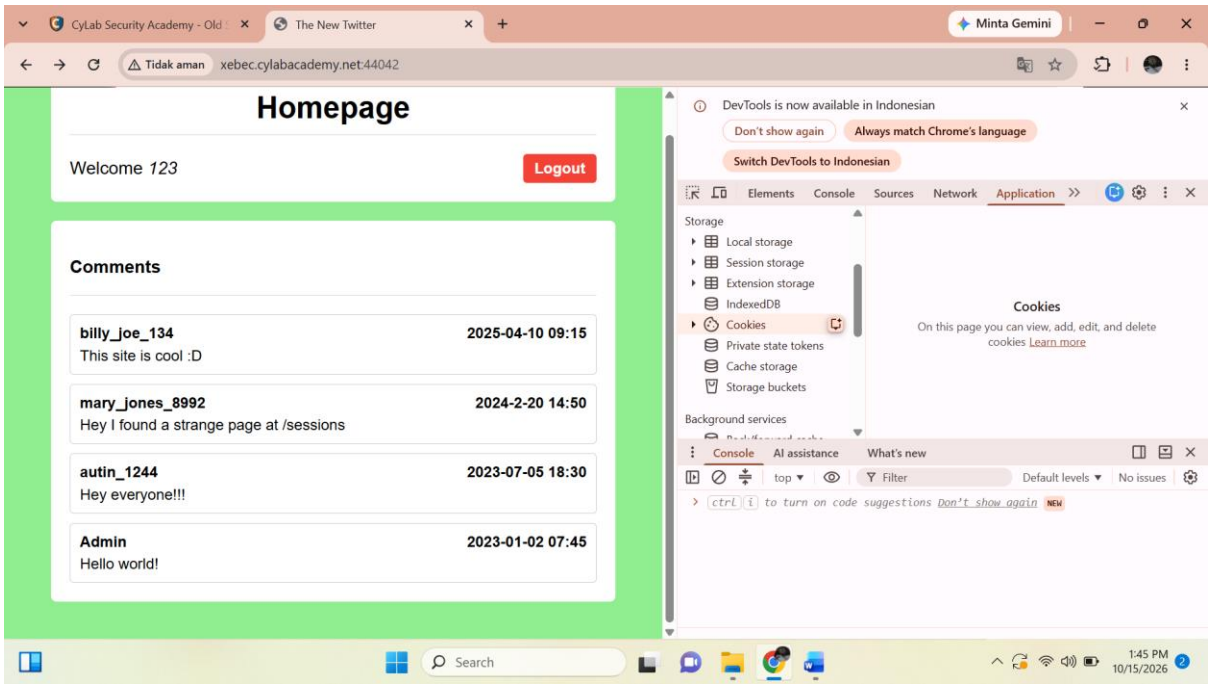
Gambar 1.8 Melakukan Inspeksi

Klik kanan pada *mouse*/*touchpad*, lalu klik inspeksi.



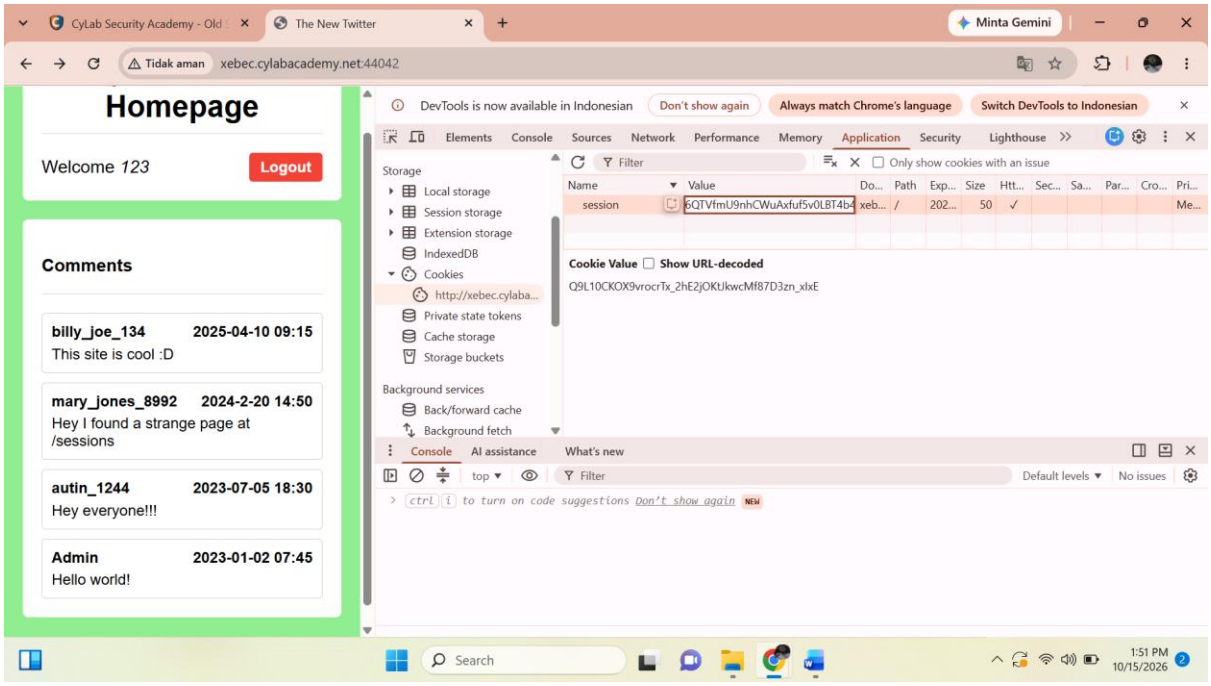
Gambar 1.9 Apllicaton

Masuk ke *application*



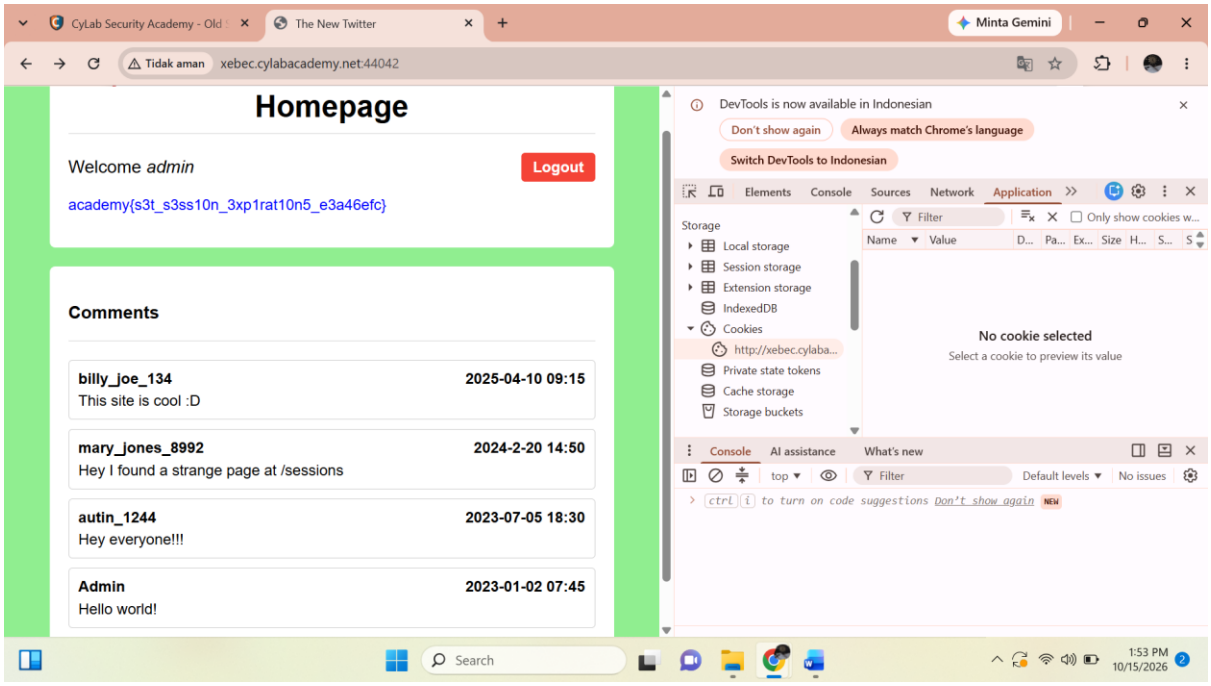
Gambar 1.10 Cari Cookies

Cari Kue nya:p



Gambar 1.11 Nama Sesi Cookies

Ubah nama sesi *Cookies*-nya dengan string sesi admin tadi. Ini yang dimaksud dengan injeksi kukis.



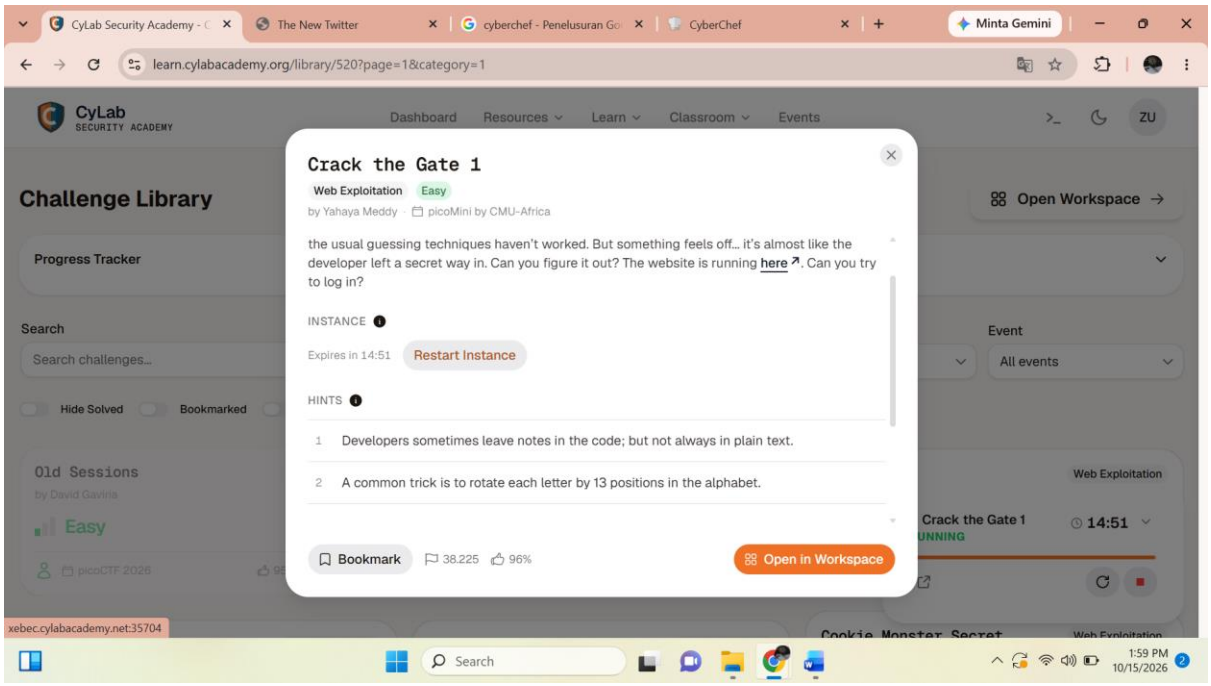
Gambar 1.12 Setelah Injeksi

Kembali cek halaman utama webnya, flagnya muncul! Ini dia flagnya.

```
academy{s3t_s3ss10n_3xp1rat10n5_e3a46efc}
```

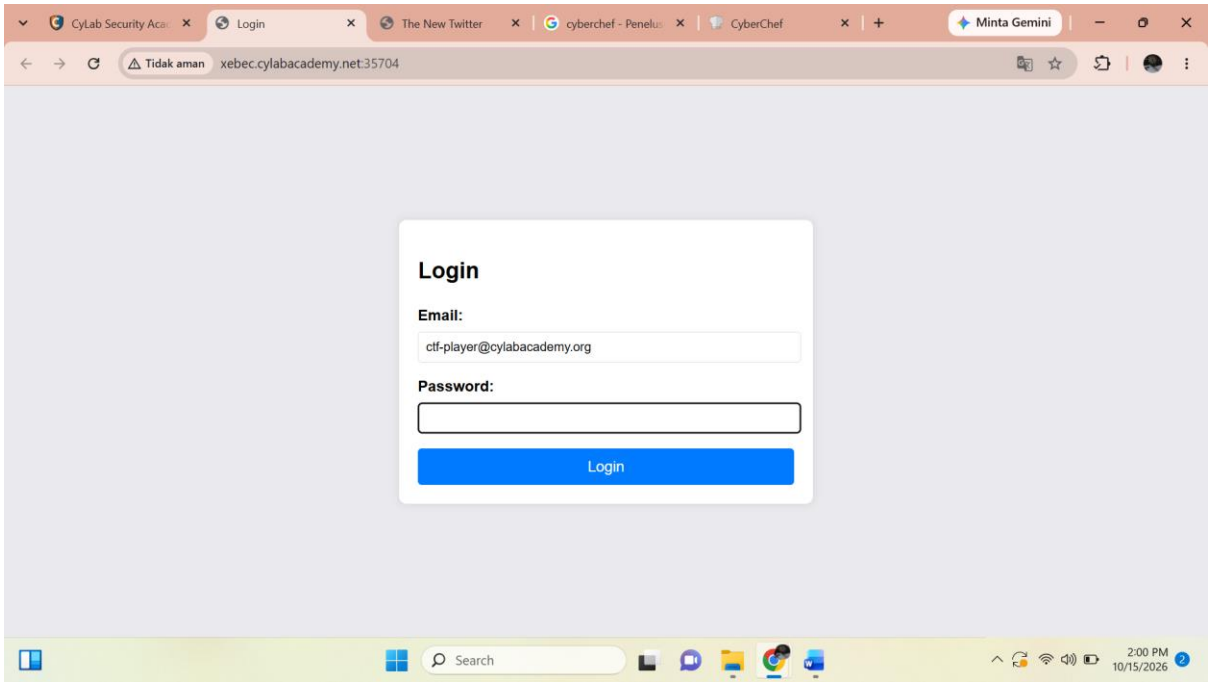
2. Web 2 – Crack The Gate 1

Link soal : *https://learn.cylabacademy.org/library?page=1&category=1*



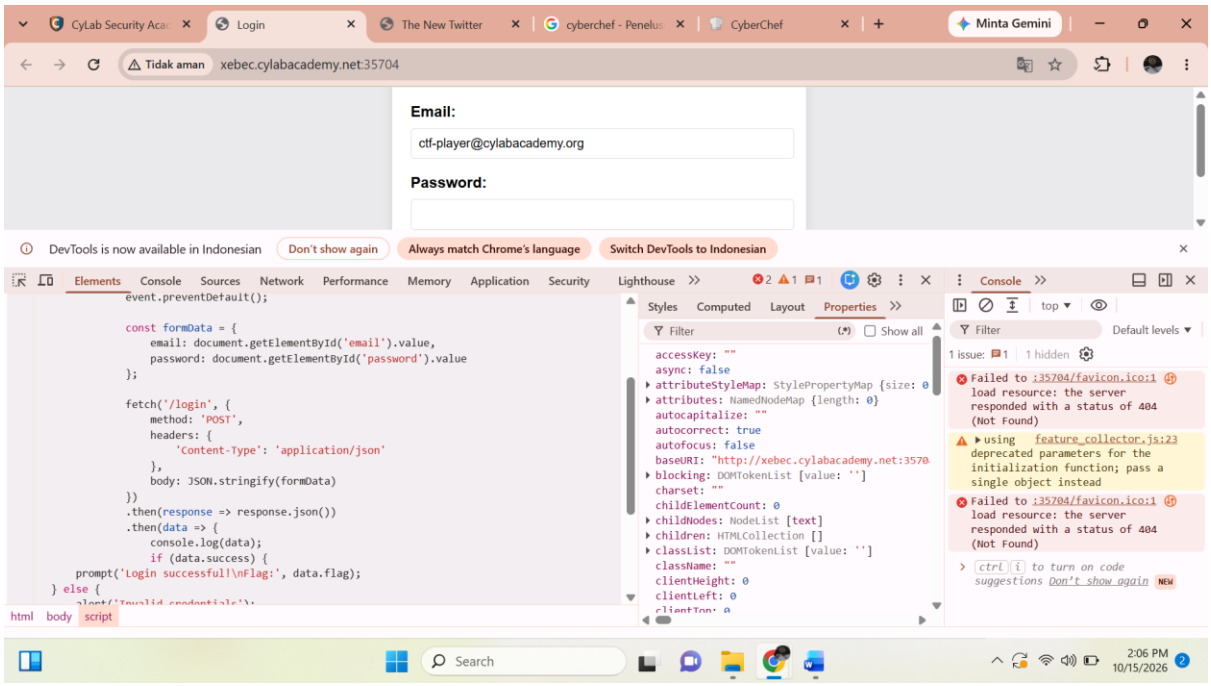
Gambar 2.1 Soal Open The Gate 1

Baca deskripsi, dan *hint* atau petunjuk terlebih dahulu, *start instance*, lalu buka tautannya. Lihat, di deskripsi. Kita dikasi email, simpen untuk selanjutnya.



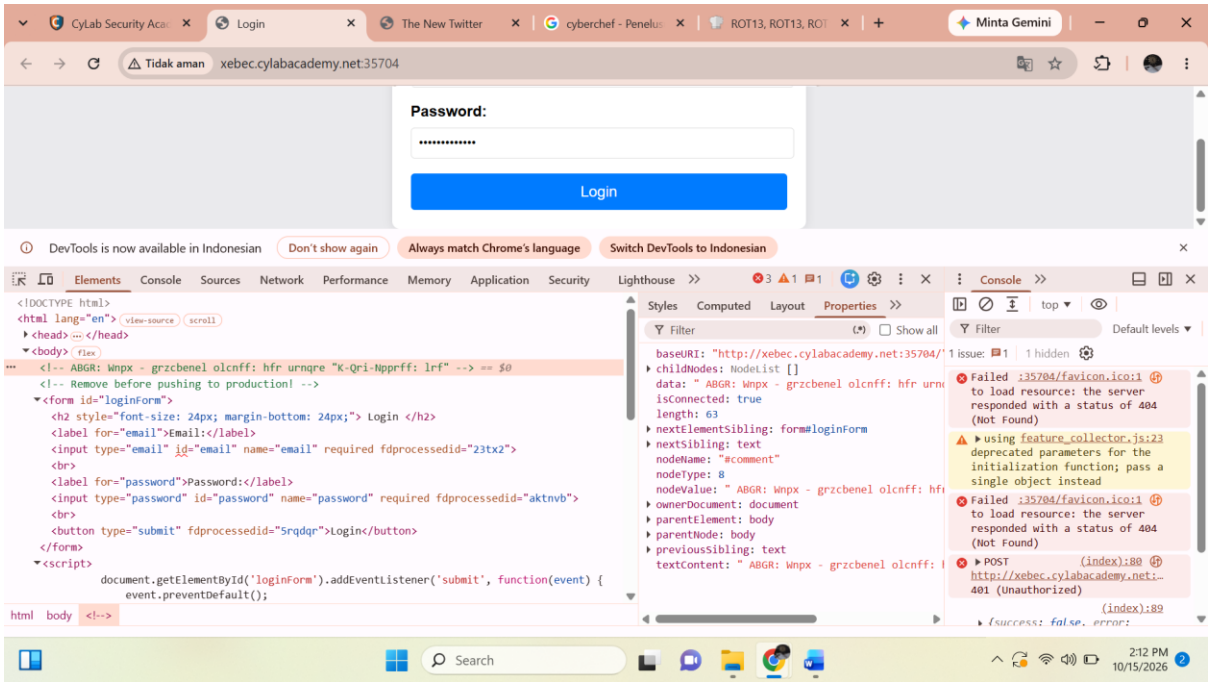
Gambar 2.2 Halaman Login

Dikasi email, jadi tinggal masukkan sajah. Tapi kita diminta cari password. Jadi, dimana cari *password*-nya? Nah, saya mencari tutorial dari youtube dan katanya perlu inspeksi.



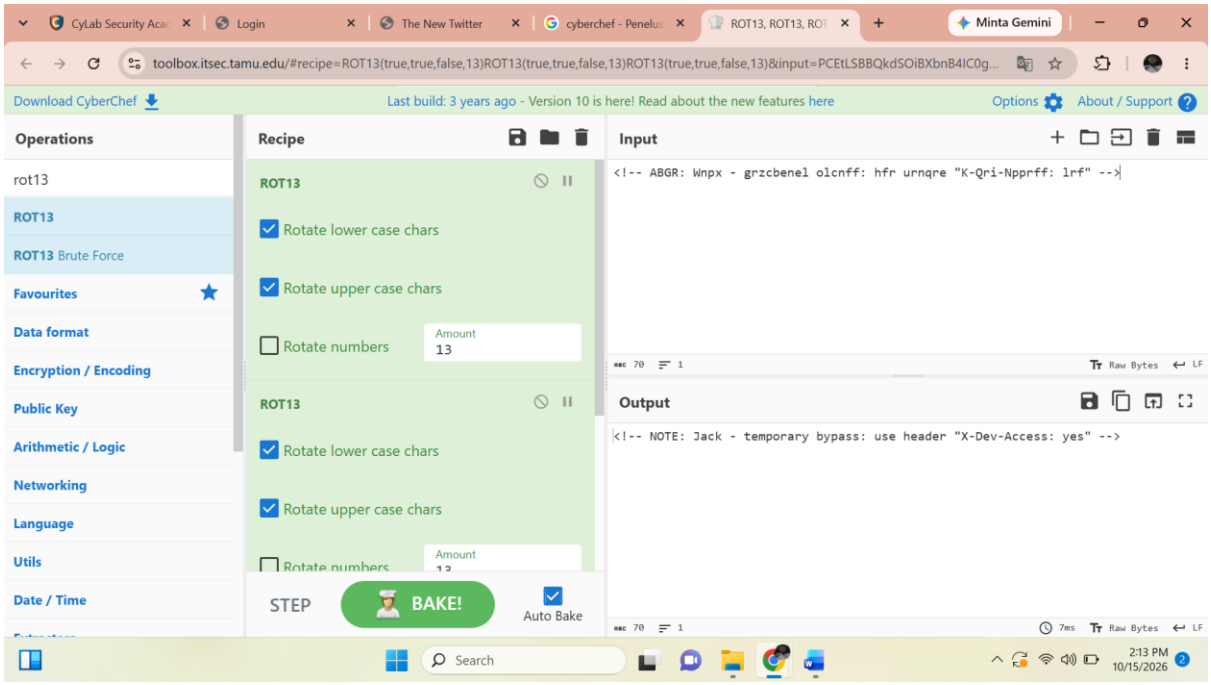
Gambar 2.3 Inspeksi

Kita inspect lagi. Di bagian script, katanya flagnya akan muncul setelah log in. Tapi, Kita masih belum menemukan passwordnya. Jadi, mungkin passwordnya ada di area bagian login, atau sekitaran body. Pokoknya kita harus analisis lagi.



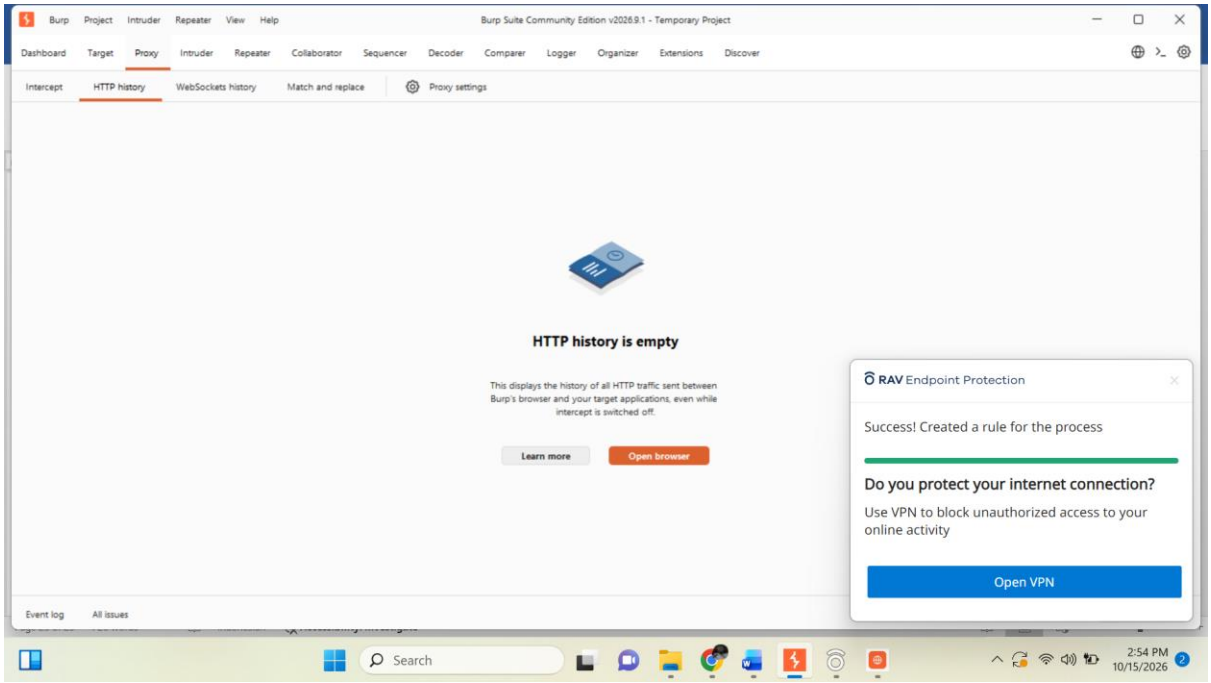
Gambar 2.4 Inspect

Disana, ada tulisan aneh ini kita dekripsi dengan ROT13 (dari petunjuk). Kita dekripsi dengan tools bernama cyberchef. Wah, unik namanya.



Gambar 2.5 CyberChef

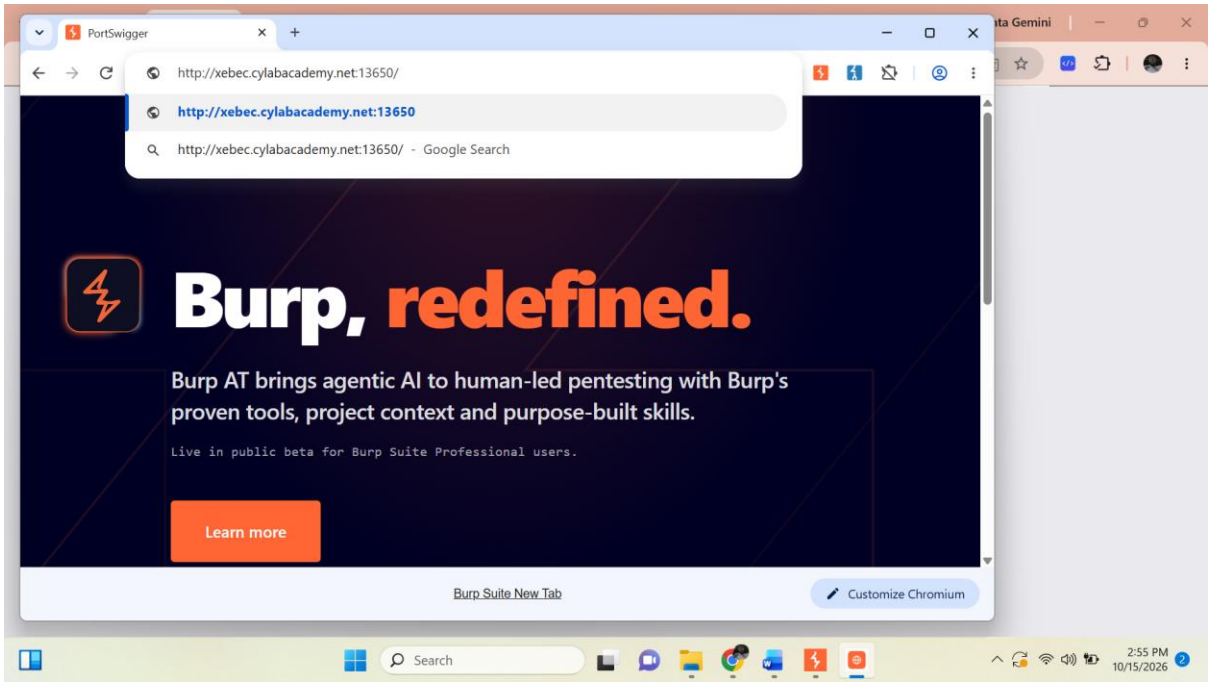
Setelah kita *copy n paste*,BAKE! Selanjutnya, kita ganti header dengan "X-Dev-Access: yes". Bagaimana caranya menganti header? Pakai tools lagi. Kali ini, pakai Burp Suite. Kalau belum punya, download terlebih dahulu. Kalau sudah ada, buka Burp Suite nya.



Gambar 2.6 Burp Suite

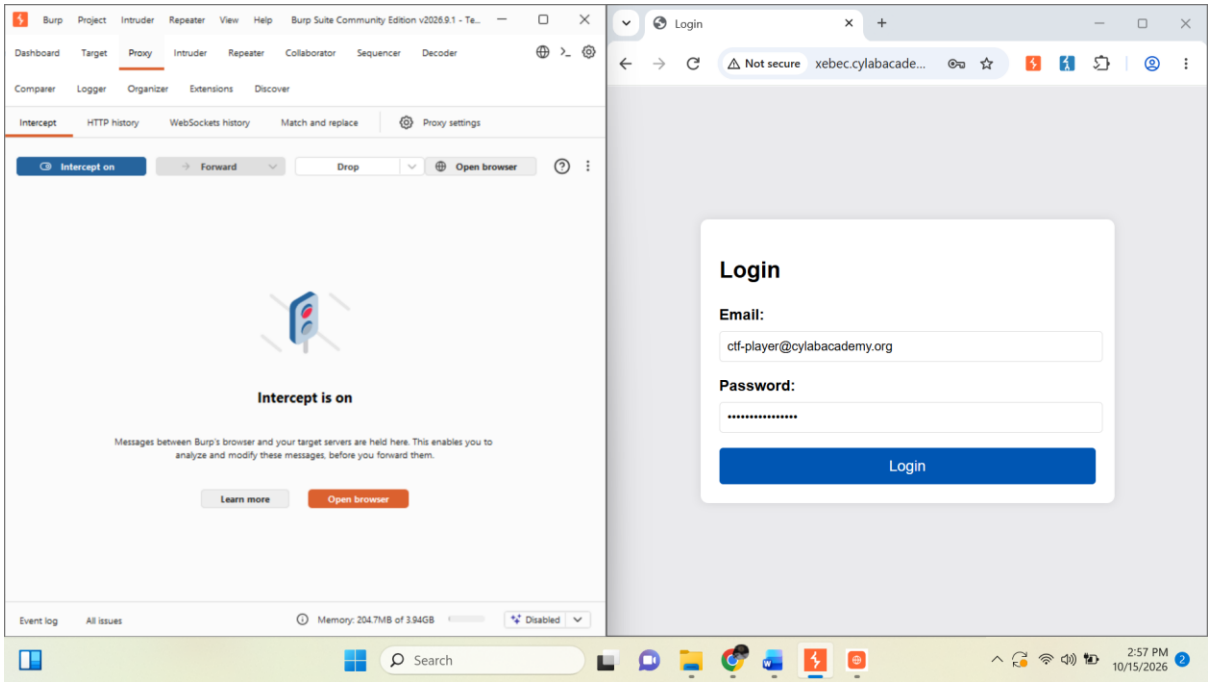
Burp Suite adalah perangkat lunak (*toolkit*) yang dikembangkan oleh PortSwigger dan sering digunakan untuk menguji dan menganalisis tingkat keamanan aplikasi web. Kali ini, kita gunakan untuk mencari flag :v

Masuk ke Proxy, lalu open browser



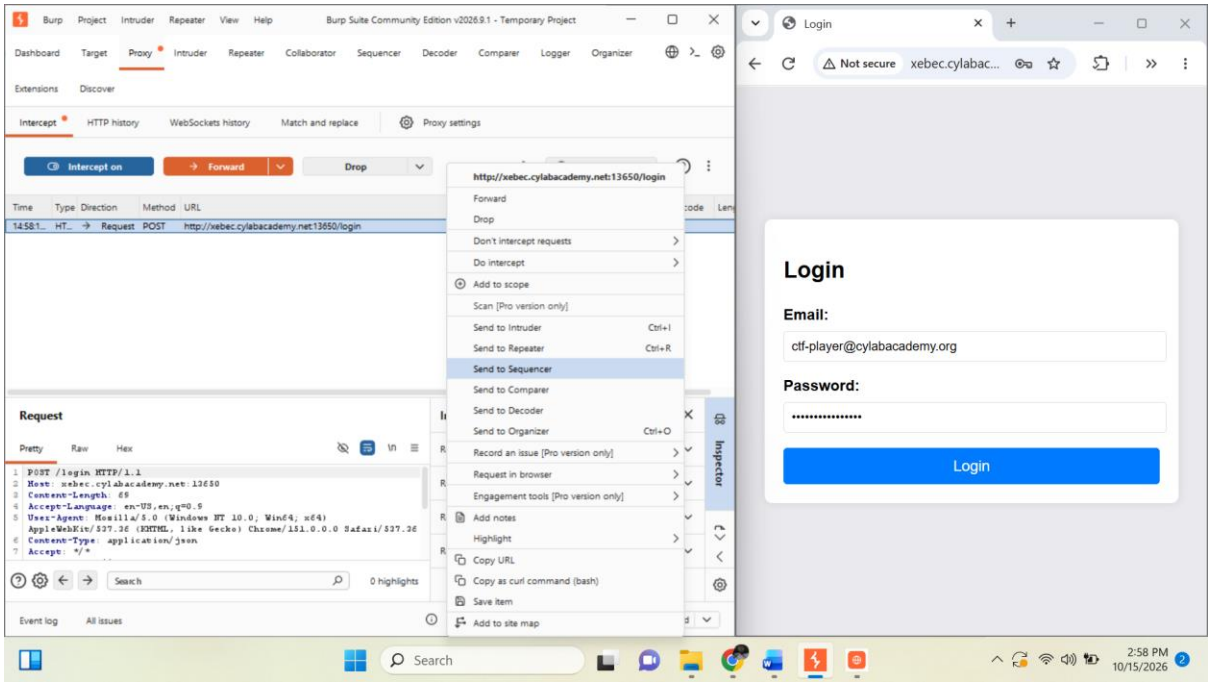
Gambar 2.7 Copas link

Copas linknya.



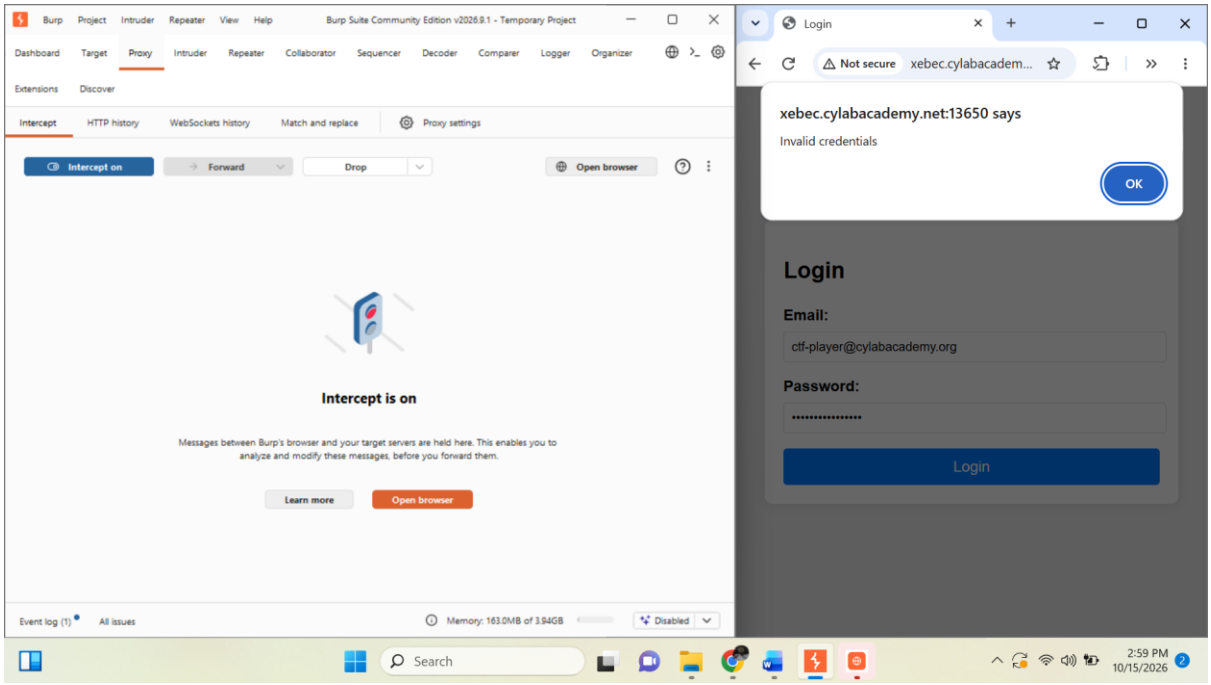
Gambar 2.8 Login

Masukkan email dan passwordnya (*random* aja), lalu log in



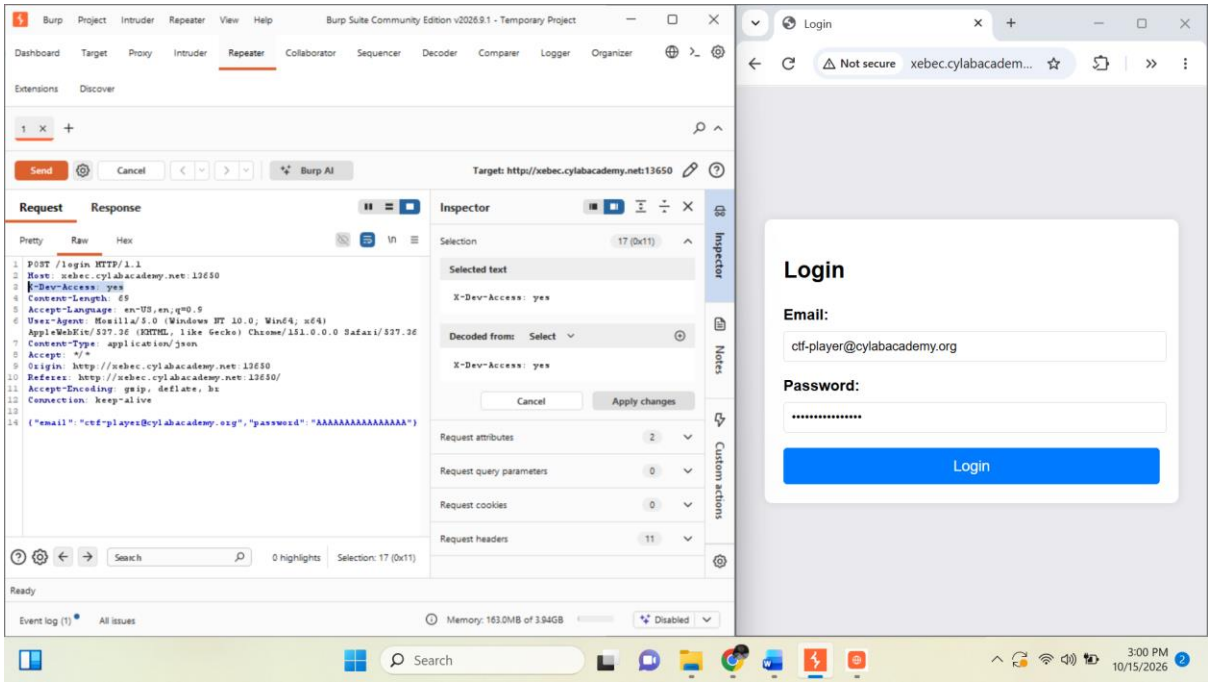
Gambar 2.9 Setelah Login dengan sandi *random*

Baris `POST /login HTTP/1.1` ini, klik kanan di atasnya, *send the repeater*, lalu *forward* yang orange itu.



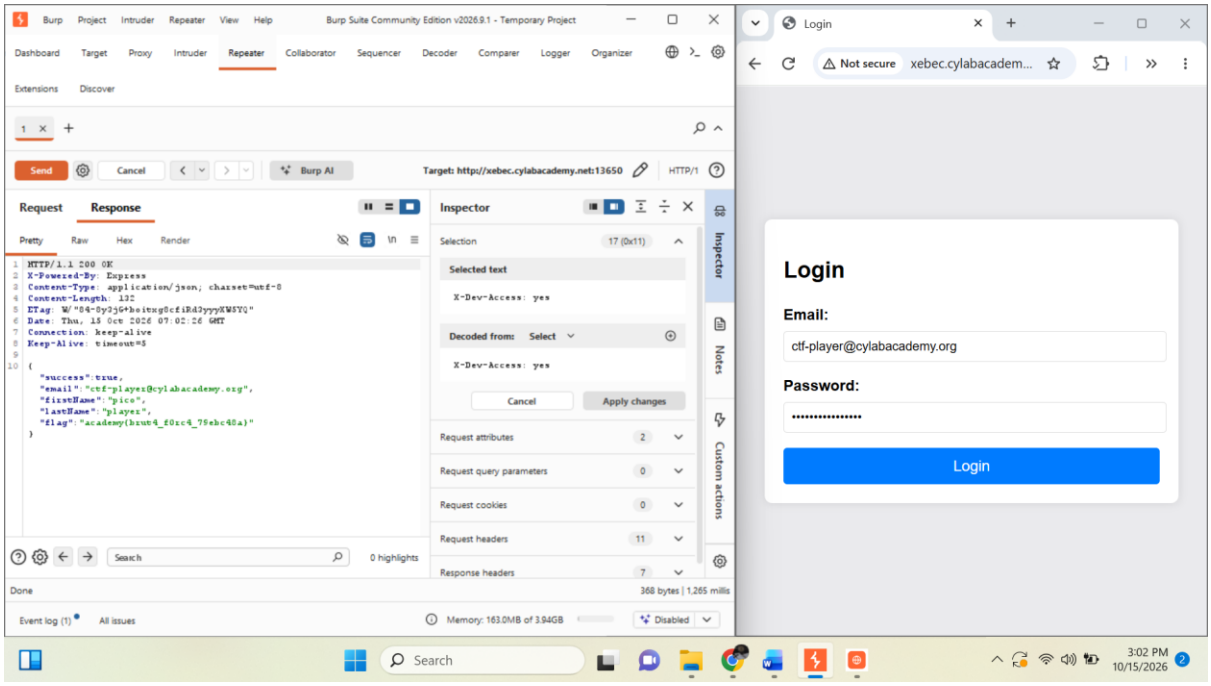
Gambar 2.10 Invalid credentials

Setelah muncul invalid credentials, klik repeater (2 button setelah proxy).



Gambar 2.11 Masukkan Header

Masukkan header yang tadi di dekripsi di cyberchef. Lalu send yang orange di atas kata request.



Gambar 2.12 Setelah Response

Lalu di response, ketemu flagnya

Flagnya adalah

```
academy{brut4_f0rc4_79ebc48a}
```

Daftar Pustaka

Cybersensei-EH. (2026). *Old sessions | PicoCTF 2026 | web exploitation*. https://www.youtube.com/watch?v=oiSvf9DCM0k

GeeksforGeeks. (2023). *What is Burp Suite?* https://www.geeksforgeeks.org/ethical-hacking/what-is-burp-suite/

Indonesia, D. (2024). *Mengungkap reverse engineering dalam software engineering*. https://www.dicoding.com/blog/mengungkap-reverse-engineering-dalam-software-engineering/

PortSwigger. (n.d.). *Burp Suite - Application security testing software*. https://portswigger.net/burp

r00t_inx. (2026). *Crack the gate 1 picoctf | CyLab Security Academy | cybersecurity*. https://www.youtube.com/watch?v=6OwR1m7I1uo